

Master TOC

PART I - FOUNDATIONS

Chapter 1 – The Case for Offensive and Defensive Security for Federal and Military Active Directory FICAM Domains and Networks

- 1.1 Why This Handbook Exists
 - 1.1.1 Purpose of This Book
 - 1.1.2 Intended Audience
 - 1.1.3 Scope and Objectives
 - 1.1.4 How to Use This Handbook
- 1.2 Understanding Identity in Modern Federal Networks
 - 1.2.1 The Evolution of Digital Identity
 - 1.2.2 Identity as the New Security Perimeter
 - 1.2.3 The Relationship Between Identity and Cybersecurity
 - 1.2.4 Identity-Centric Security in Government Networks
- 1.3 Active Directory as the Foundation of Enterprise Security
 - 1.3.1 What Active Directory Is and What It Isn't
 - 1.3.2 Core Components of Active Directory
 - 1.3.3 Authentication, Authorization, and Accounting
 - 1.3.4 Why Active Directory Remains Mission Critical
 - 1.3.5 Active Directory in Large-Scale Federal Enterprises
- 1.4 The Federal Identity Challenge
 - 1.4.1 Managing Millions of Identities
 - 1.4.2 Balancing Security and Accountability
 - 1.4.3 Interagency Collaboration Requirements
 - 1.4.4 Insider Threat Considerations
 - 1.4.5 Identity Risks in National Security Environments
- 1.5 Introduction to Federal Identity, Credential, and Access Management (FICAM)
 - 1.5.1 What Is FICAM?
 - 1.5.2 Origins and Evolution of FICAM
 - 1.5.3 FICAM Objectives
 - 1.5.4 Identity, Credential, and Access Management Components
 - 1.5.5 FICAM as a Strategic Framework
- 1.6 Active Directory Within FICAM Architecture
 - 1.6.1 Active Directory As an Identity Provider (IdP)
 - 1.6.2 Directory Services and Credential Management
 - 1.6.3 Federation and Trust Relationships
 - 1.6.4 Integration with Public Key Infrastructure (PKI) and Smart Cards
 - 1.6.5 Active Directory's Role in Zero Trust Architecture
- 1.7 The Federal Identity Ecosystem
 - 1.7.1 Key Federal Identity Stakeholders
 - 1.7.2 How Governance Influences Technical Implementation
 - 1.7.3 The Relationship Between Policy and Technology
 - 1.7.4 Preparing for FICAM Governance and Compliance
- 1.8 Why Federal Active Directory Is Different
 - 1.8.1 Command and Combatant Mission Assurance Requirements
 - 1.8.2 National Security Considerations
 - 1.8.3 Compliance and Regulatory Obligations
 - 1.8.4 Operational Complexity in Government Networks
 - 1.8.5 Identity as Critical Infrastructure

1.9 Chapter Summary

1.9.1 Key Concepts Reviewed

1.9.2 Active Directory's Role in Federal Cybersecurity

1.9.3 Transition to Federal Identity Governance and FICAM Authorities

1.9.4 The Evolution of Active Directory Security Infrastructure: Tracking Active Directory (AD) From an Unauthenticated Information Technology (IT) Directory to a Primary Nation-State Target and Zero Trust Security Boundary

1.9.5 The Gap Between Commercial and Federal/Military Directory Deployments: Weaponizing and Defending Custom Enterprise Enclaves to Create Unique Exploitation Surfaces

1.9.5.1 Exploiting Air-Gapped Networks and Multi-Enclave Cross-Domain Solutions

1.9.5.2 Mission-Partner Network Exploitation

1.9.6 Limitations of Conventional Active Directory Manuals: Exposing Why Corporate Active Directory Manuals Leave Information Systems Vulnerable to Tactical Edge Exploits, Military Command Structure Takeovers, and Smart Card Bypasses

1.9.6.1 Smart Card List Manipulation

1.9.7 The Shift to Directory-Level Security Architecture: Demolishing Perimeter Defenses and Treating the Authentication Engine as an Active Tactical Firewall Where Domain Rights Equal Total Domain Control

1.9.8 Defining the Target Audience: Arming Federal Civilian and Contractor Personnel, Military Cyber Operators, Federal Chief Information Security Officers (CISOs), Red, Blue, and Purple Teams, Security Engineers, Enterprise Defenders, Security Engineers, and Systems Administrators with Offensive Exploits and Defensive Hardening Frameworks – While Explicitly Mentoring Newcomers Entering Their First Federal Cybersecurity Roles as Junior Penetration Testers, Ethical Hackers, or Security Analysts

1.10 Understanding Federal Identity, Credential, and Access Management (FICAM)

1.10.1 Origins of Federal Identity Management Programs: Tracing Historical Policy Gaps and How Legacy Credential Silos Created Systemic Blind Spots That Advanced Persistent Threats (APTs) Exploit to This Very Day

1.10.2 Identity Management Components: Offensive Targeting of Administrative Onboarding Pipelines Versus Defensive Automation of Authoritative Personnel Data Sources and Unique Enterprise Identifiers

1.10.3 Credential Management Components: Adversarial Theft of Cryptographic Token Infrastructure Versus Blue Team Enforcement of Biometric Registration, and Rapid Hardware Token Revocation

1.10.4 Access Management Components: Brute-Forcing and Bypassing Multi-Factor Authentication (MFA) Versus Implementing Granular Role-Based and Attribute-Based Access Control (RBAC/ABAC) Kill-Switches

1.10.5 Active Directory Federation Services (AD FS) and Forest Trust Relationships: Forging Cross-Agency Single Sign-On (SSO) Authentication Claims Versus Locking Down Inter-Service Token Boundaries

1.10.6 FICAM as a Mission Enabler: Balancing Information Availability with Security; Preventing Attackers From Pivoting Across Tactical Networks and Domains During Joint-Force Operations

1.11 Active Directory's Role Within Federal and Military Identity,

Credential, and Access Management (FICAM) Ecosystems

1.11.1 Active Directory as an Identity Provider (IdP): Hostile Scanning and Enumeration of Domain User Metadata Schemas (Clearances, Rank) for Targeted Spearphishing Versus Using Fake or Spoofed Accounts as Defensive Tripwires

1.11.2 Active Directory as an Authorization Platform: Subverting Group-Based Permissions and Kerberos Tickets for Lateral Movement Versus Isolating Discretionary Access Bounds Over Tier 0 Assets

1.11.3 Active Directory as an Enterprise Trust Anchor: Exploiting Transitive Forest Relationships to Hop Across Military Service Branches Versus Engineering Hard Boundary Isolation Models via Defense-in-Depth Approaches

1.11.4 Integration with Public Key Infrastructure (PKI) and Smart Card Authentication: Bypassing Mandatory Card Logins via Certificate Template Flaws Versus Enforcing Near-Real-Time Online Certificate Status Protocol (OCSP) Revocation Checking

1.11.5 Integration with Cloud Identity Providers (CIIdP): Abusing Hybrid Identity Synchronization Engines to Pivot From On-Premises AD to Microsoft Entra ID or Amazon Web Services (AWS) GovCloud Versus Routing Near-Real-Time Telemetry Logs to Cloud Analytics Suites

1.11.6 Active Directory's Continuing Relevance in Zero Trust Architecture (ZTA): Poisoning High-Fidelity Security Attributes Fed Into Modern Policy Decision Engines Versus Weaponizing AD Data Strings to Enforce Long-Term Network Micro-Segmentation

1.12 Commercial and Public-Sector Active Directory Versus Federal/Military Active Directory

1.12.1 Business Objectives Versus Mission Objectives: How Attackers Exploit Corporate Uptime Goals to Spread Ransomware Versus Countering Threat Actors Intent on Destroying Military Command, Control, and Communications (C3) Survivability

1.12.2 Risk Appetite and Tolerance Differences: Exploiting Corporate Financial Risk Acceptance Versus Hunting Within a Military Defense-in-Depth Framework Where Any Security Breach Threatens Mission Assurance

1.12.3 Compliance Requirements and Regulatory Drivers: Capitalizing on Regulatory Text Flaws to Achieve Compliance on Paper While Leaving Technical Backdoors Open Versus Auditing Actual Directory Posturing

1.12.4 Common Access Card (CAC) and Personal Identity Verification (PIV) Requirements: Forging Derived Credentials and Bypassing Smart Card Restrictions Versus Locking Down Hard-Enforced Smart Card Authentication Policies

1.12.5 Risk Management Framework (RMF), STIGs, SRGs, and Continuous Monitoring (ConMon) Expectations: How Attackers Predict Network Configurations by Studying Mandatory Security Technical Implementation Guides (STIG) and Security Requirements Guides (SRGs) Versus Weaponizing Continuous Monitoring to Catch Non-Compliant Anomalies

1.12.6 Command and Combatant Operational Readiness Versus Business Continuity: Balancing Business Revenue Recovery Against Warfighter Operational Availability and Command, Control, and Communications (C3) Survivability

1.12.7 Case Comparison: Commercial Enterprise Domain Versus Federal Enterprise Domain: A Direct, Adversarial Architectural Review of a Corporate Network Versus a Secure Defense Domain Under Fire

1.13 Active Directory as High-Value Cyber Terrain

1.13.1 Why Attackers Target Identity Systems: Deconstructing Why the Centralized

Database of Enterprise Privileges is the Ultimate Prize for Any Network Intruder

1.13.2 The Evolution from Network-Centric to Credential-Focused Attacks: Moving From Loud Port Scanning, Probing, and Remote Code Execution (RCE) to Quiet Credential Harvesting and Living-Off-The-Land (LOTL) Techniques

1.13.3 Credential Theft as an Operational Objective: Adversarial Playbooks for Capturing High-Value Domain Secrets Versus Blue Team Strategies for Rendering Stolen Tokens Useless

1.13.4 Privilege Escalation and Identity Dominance: Mapping the Path From Local Workstation Compromise to Full Domain Administrator Takeover

1.13.5 Identity Infrastructure as a Pathway to Mission Disruption: How Compromising the Directory Allows Nation-State Threat Actors to Freeze Command-and-Control, Military Logistics, and Troop Deployment Pipelines

1.13.6 Active Directory as a Strategic Target for Nation-State Adversaries: Analyzing APT Group Tactics, Techniques, and Procedures (TTPs) Aimed Specifically at Destabilizing Federal Identity Backbones

1.14 Understanding the Federal and Military Identity Attack Surface

1.14.1 Active Directory Domain Services (AD DS):

1.14.1.1 Offensive: Exploit Core Domain Controllers, Directory Partitions, and Replication Protocols

1.14.1.2 Defensive: Monitor Domain Modification Logs

1.14.2 Active Directory Certificate Services (AD CS):

1.14.2.1 Offensive: Abuse Misconfigured Public Key Infrastructure (PKI) Templates for Instant Domain Takeover

1.14.2.2 Defensive: Audit and Lock Down Certificate Enrollment Rights

1.14.3 Active Directory Federation Services (AD FS):

1.14.3.1 Offensive: Steal Token-Signing Keys to Forge Persistent Authentication Cookies

1.14.3.2 Defensive: Enforce Strict Hardware Isolation Rules on Federation Servers

1.14.4 Microsoft Entra ID and Hybrid Identity Components:

1.14.4.1 Offensive: Exploit Directory Sync Service Accounts to Escalate Privileges Across Cloud and On-Premises Environments

1.14.4.2 Defensive: Hunt for Hybrid Sync Anomalies

1.14.5 Public Key Infrastructure (PKI):

1.14.5.1 Offensive: Target Vectors Against Root Certification Authorities (CAs) and Certificate Trust Lists

1.14.5.2 Defensive: Deploy Strict Path-Validation Defenses

1.14.6 Domain and Forest Trust Relationships:

1.14.6.1 Offensive: Bypass Cross-Forest Security Filters to Access Linked Domains

1.14.6.2 Defensive: Deploy Strict Path-Validation Defenses

1.14.7 Privileged Access Workstations (PAWs) and Secured Administrative Workstations (SAWs):

1.14.7.1 Offensive: Hijack Administrative Sessions on Jump Servers and Consoles

1.14.7.2 Defensive: Implement Clean-Source Engineering Principles

1.14.8 Identity Synchronization Services (ISS):

1.14.8.1 Offensive: Dump Synchronization Databases to Extract Cached Directory Hashes

1.14.8.2 Defensive: Isolate Sync Host Servers From the Public Network

1.15 Responsible Authorities for Federal and Military Identity Security

1.15.1 Authorizing Officials (AOs): Exploitative-Driven Blind Spots in Risk Acceptance and Educating Leadership to Refuse Authority to Operate (ATO) Sign-Off for Misconfigured Directories

1.15.2 System Owners: Target-Rich Procurement Cycles That Introduce Unpatched Supply Chain Software and Enforcing Security-Focused Engineering During Systems Acquisitions

1.15.3 Information Systems Security Managers (ISSMs) and Information Systems Security Officers (ISSOs): Prevent Exploitation of Check-the-Box Compliance Vulnerabilities and Turning ISSM's and ISSO's Into Active, Directory-Level Threat Hunters

1.15.4 Active Directory Security Engineers and Systems Architects: Avoid Overwhelming Complex Forest Designs with Configuration Drift with Minimalist Engineered, Defensible, and Hardened Directory Architectures

1.15.5 Cybersecurity Service Providers (CSSPs): Detect Blinding Security Operations Center (SOC) Network Traffic Monitoring via Encrypted Network Protocols and Building Specialized Detections for Directory Tampering Events

1.15.6 Security Control Assessors (SCAs): Evading Paper-Based Compliance Audits by Running Aggressive, Script-Based Verification Checks Against Production Domain Controllers

1.15.7 Red Teams, Purple Teams, Blue Teams, Penetration Testers, and Ethical Hackers: Breach & Adversarial Simulation (BAS) Exercises That Mimic Real-World Nation-State Threat Campaigns to Expose Hidden Attack Pathways and Build Resilient Directory Detection Metrics

1.16 Offensive and Defensive Perspectives of Federal and Military Active Directory Security

1.16.1 How Attackers View Federal Identity Infrastructure: Seeing a Single Graph of Interconnected Permissions, Legacy Protocols, and Misconfigured Service Accounts Ripe for Exploitation

1.16.2 How Enterprise Defenders View Federal Identity Infrastructure: Balancing Operational Uptime with Proactive Attack-Path Reduction, Log Analysis, and System Hardening

1.16.3 How Security Control Assessors and Auditors Evaluate Federal and Military Identity Risk: Moving Beyond Checklist Compliance to Actively Measure a Domain's Empirical Resistance to Credential Theft and Privilege Escalation

1.16.4 Bridging Offensive Findings and Defensive Improvements: Establishing a Continuous Purple Team Loop to Turn Successful Penetration Tests Into Immediate Directory Configuration Fixes

1.16.5 The Importance of Breach & Adversary Simulation (BAS): Using Automated Exploit Platforms to Constantly Challenge and Validate the Efficacy of Directory Defenses

1.17 The Future of Federal Identity Systems (FIS)

1.17.1 Zero Trust Network Architecture (ZTNA):

1.17.1.1 Offensive: Bypass Micro-Segmentation by Stealing Valid Identity Tokens

1.17.1.2 Defensive: Dynamically Revoke Sessions Based on Real-Time User Risk

Scoring

1.17.2 Passwordless Authentication:

1.17.2.1 Offensive: Target Vectors Against Hardware-Backed Credentials

1.17.2.2 Defensive: Eliminate the Entire Human Password Attack Surface

1.17.3 FIDO2 and Phishing-Resistant MFA:

1.17.3.1 Offensive: Finding Gaps in Fast Identity Online 2 Session

Implementations

1.17.3.2 Defensive: Deploy Cryptographic Barriers to Stop

Adversary-in-the-Middle (AitM) Attacks

1.17.4 Hybrid Identity Architecture:

1.17.4.1 Offensive: Exploit the Complex Web of Synchronized On-Premises Infrastructure and Cloud Enclaves

1.17.4.2 Defensive: Implement Unified, Cross-Environment Identity Monitoring

1.17.5 Cloud-Native Identity Services:

1.17.5.1 Offensive: Identify Net-New Exploitation Vectors in Pure Cloud Environments

1.17.5.2 Defensive: Migrate Away From Legacy, On-Premises Directory Infrastructure Code Bases

1.17.6 The Authentication Tier as the New Security Perimeter:

1.17.6.1 Offensive: Subvert Cryptographic Authorization Tokens to Gain Lateral Movement

1.17.6.2 Defensive: Treat Hardened Access Tokens as the Absolute Edge of Network Security

1.18 Case Study: Compromise of Federal and Military Identity, Credential, and Access Management (ICAM) Infrastructure

1.18.1 Initial Access: Executing Spearphishing Attacks and Weaponizing Client-Side Exploits to Secure an Internal Government Workstation Foothold

1.18.2 Credential Theft: Dumping Local Memory and Harvesting Cached Passwords to Compromise Local Service Accounts

1.18.3 Active Directory Enumeration: Running Stealthy, Low-and-Slow Directory Queries to Map Out High-Value Domain Objects Without Triggering Defensive Alerts

1.18.4 Privilege Escalation: Abusing Legacy Directory Permissions and Misconfigured Security Groups to Claim Full Domain Administrator Rights

1.18.5 Federation Abuse: Generating a Golden SAML Token to Bypass External Multi-Factor Authentication (MFA) Systems and Access Cloud Networks

1.18.6 Mission Impact: Paralyzing Joint-Task Force Command Communications and Exfiltrating Classified Defense Intelligence

1.18.7 Detection Opportunities: Identifying the Exact Event IDs, Protocol Anomalies, and Log Trails That Should Have Stopped the Attack and Triggered Defensive Alarms

1.18.8 Lessons Learned: Implementing Rapid Architectural Mitigation to Immunize Identical Federal Networks Against Similar Attack Patterns to Avoid Repeating Future Similar Failures

PART I - FOUNDATIONS

Chapter 2 – Federal Identity Governance and FICAM Authorities

2.1 Introduction

2.1.1 Chapter Objectives

2.1.2 Understanding Federal Identity Governance

- 2.1.3 Governance Versus Technical Implementation
- 2.1.4 Identity as a Strategic National Asset
- 2.2 Historical Evolution of Federal Identity Management
 - 2.2.1 Federal Identity Before Homeland Security Presidential Directive-12 (HSPD-12)
 - 2.2.2 Post-9/11 Security Transformation
 - 2.2.3 Homeland Security Presidential Directive-12 (HSPD-12)
 - 2.2.4 Federal Information Processing Standard (FIPS) 201
 - 2.2.5 Emergence of Identity, Credential, and Access Management (ICAM) Programs
 - 2.2.6 Evolution From ICAM to FICAM
 - 2.2.7 Identity Governance in the Modern Zero Trust Era
- 2.3 Federal Identity Governance Structure
 - 2.3.1 Executive Branch Oversight
 - 2.3.2 Legislative and Regulatory Influences
 - 2.3.3 Federal Agency Responsibilities
 - 2.3.4 Shared Service Providers
 - 2.3.5 Policy Development and Implementation Lifecycle
 - 2.3.6 Governance-to-Operations Workflow
- 2.4 Office of Management and Budget (OMB)
 - 2.4.1 OMB's Role in Federal Cybersecurity
 - 2.4.2 OMB Circular A-130
 - 2.4.3 OMB Memoranda and Identity Management
 - 2.4.4 OMB M-19-17 and Identity Modernization
 - 2.4.5 OMB M-22-09 and Zero Trust Strategy
 - 2.4.6 Compliance Reporting and Accountability
- 2.5 National Institute of Standards and Technology (NIST)
 - 2.5.1 NIST's Role in Federal Standards Development
 - 2.5.2 NIST Cybersecurity Special Publications (SP)
 - 2.5.3 NIST SP 800-53 Security Control Families
 - 2.5.4 NIST SP 800-63, Digital Identity Guidelines
 - 2.5.5 NIST SP 800-207, Zero Trust Architecture
 - 2.5.6 Influence on Federal Identity Programs
- 2.6 Department of Homeland Security (DHS) and Cybersecurity Infrastructure Security Agency (CISA)
 - 2.6.1 DHS Cybersecurity Responsibilities
 - 2.6.2 Cybersecurity and Infrastructure Security Agency (CISA)
 - 2.6.3 Continuous Diagnostics and Mitigation (CDM)
 - 2.6.4 Federal Civilian Executive Branch Support
 - 2.6.5 Identity-Centric Security Initiatives
- 2.7 Department of Defense (DoD) Identity Governance
 - 2.7.1 DoD Identity Management Strategy
 - 2.7.2 Office of the DoD Chief Information Officer (CIO)
 - 2.7.3 Joint Information Environment (JIE)
 - 2.7.4 Command and Combatant Mission Assurance and Identity Security
 - 2.7.5 Identity Requirements Across Classification Domains
 - 2.7.6 Identity Governance in Military Operations
- 2.8 Defense Information Systems Agency (DISA)
 - 2.8.1 DISA Mission and Responsibilities
 - 2.8.2 Enterprise Identity Services
 - 2.8.3 Security Requirements Guides (SRGs)

- 2.8.4 Security Technical Implementation Guides (STIGs)
- 2.8.5 Enterprise Directory Services (EDS)
- 2.8.6 Identity Services Supporting Zero Trust
- 2.9 Federal Public Key Infrastructure Governance
 - 2.9.1 Federal PKI Overview
 - 2.9.2 Federal Bridge Certification Authority
 - 2.9.3 Trust Framework Architecture
 - 2.9.4 Certificate Policy Governance
 - 2.9.5 Cross-Certification Models
 - 2.9.6 Federal Credential Trust Relationships
- 2.10 FICAM Governance Framework
 - 2.10.1 FICAM Governance Objectives
 - 2.10.2 Identity Governance
 - 2.10.3 Credential Governance
 - 2.10.4 Access Governance
 - 2.10.5 Federation Governance
 - 2.10.6 Lifecycle Governance
 - 2.10.7 Governance Metrics and Performance Measurement
- 2.11 Governance in the Zero Trust Era
 - 2.11.1 Executive Order (EO) 14028
 - 2.11.2 Identity as the Zero Trust Control Plane
 - 2.11.3 Continuous Authentication Requirements
 - 2.11.4 Risk-Based Access Decision Frameworks
 - 2.11.5 Future Federal Identity Challenges
- 2.12 Chapter Summary
 - 2.12.1 Key Concepts Reviewed
 - 2.12.2 Governance Hierarchy Recap
 - 2.12.3 Preparing for Risk Management Framework (RMF) Integration
 - ***
 - 2.12.4 Governance Versus Operations: How Attackers Exploit the Lag Between Strategic Executive Rule-Making and Daily Administrative Patching
 - 2.12.5 Governance Versus Compliance: Slipping Under the Radar of Checklist Compliance Audits by Mimicking Authorized, Check-the-Box System Configurations
 - 2.12.6 Governance Versus Risk Management: Exploiting Rigid Top-Down Rules That Fail to Address Dynamic, Near-Real-Time Directory Security Risks
 - 2.12.7 How Federal Cybersecurity Authority Flows Through Government and Military Bodies: Targeting the Gaps Where Statutory Authority Transitions Across Civilian, Intelligence, and Defense Agencies
 - 2.12.8 Legislative, Executive, Regulatory, and Operational Authorities: Navigating Conflicting Legal and Operational Directives to Find Unhardened Network Enclaves
 - 2.12.9 Why Governance Directly Correlates with Overall Active Directory Security Posture: How Weak Strategic Enforcements Directly Translate Into Easily Compromised Directory Infrastructure
- 2.13 United States Federal Laws Driving Cybersecurity and Federal Identity Security Programs
 - 2.13.1 The Federal Information Security Modernization Act (FISMA):
 - 2.13.1.1 Offensive: Exploit Reporting Delays in Annual FISMA Audits
 - 2.13.1.2 Defensive: Use Automated Continuous Diagnostics to Spot Active Domain Tampering Attempts

- 2.13.2 Homeland Security Directory Services Authorities:
 - 2.13.2.1 Offensive: Target Inter-Agency Data Pipeline Bridges
 - 2.13.2.2 Defensive: Enforce Cross-Departmental Boundary Security
- 2.13.3 Clinger-Cohen Act and Information Technology (IT) Governance:
 - 2.13.3.1 Offensive: Target Insecure, Rapidly Procured Shadow IT Assets
 - 2.13.3.2 Defensive: Enforce Strict Security Reviews on All Incoming Infrastructure Acquisitions
- 2.13.4 Federal Privacy and Data Protection Requirements:
 - 2.13.4.1 Offensive: Harvest Classified and Sensitive Personally Identifiable Information (PII) Out of Directory Schema Fields
 - 2.13.4.2 Defensive: Deploy Object-Level Conditional Access Filtering
- 2.13.5 National Security System (NSS) Authorities:
 - 2.13.5.1 Offensive: Probe the Boundaries Where High-Security Intelligence Networks Connect to Standard Logistics Networks
 - 2.13.5.2 Defensive: Implement Hard Cryptographic Cross-Domain Isolation Controls
- 2.13.6 Legislative Drivers Behind Federal Identity Security Programs: Analyze Historical Gaps in Congressional Mandates That Allowed User Databases to Remain Unhardened for Decades
- 2.13.7 How Federal Laws Influence Active Directory Security Requirements: Weaponizing High-Level Legislative Mandates to Force Budget Allocation for Active Directory Defensive Engineering
- 2.14 United States Government Executive Branch Cybersecurity Leadership
 - 2.14.1 The White House, National Cybersecurity Strategy, and HSPD-12: Forcing Attacks to Move Away From Legacy Password Attacks by Executing Homeland Security Presidential Directive-12 Card-Enforcement Mandates
 - 2.14.2 Executive Orders (EOs) and Cybersecurity Modernization: The Race Against Time; How Attackers Exploit the Implementation Window of New Presidential Directives Enforcing Zero Trust Architecture
 - 2.14.3 Office of Management and Budget (OMB): Targeting Underfunded Agency Security Programs and Leveraging OMB Financial Control Tools to Force Immediate Directory Upgrades
 - 2.14.4 OMB Memoranda Affecting Federal Identity Programs: Monitoring Federal Mandate Deadlines to Predict When Agencies Are Rushing to Identify Configurations and Using Strict Timelines to Purge Stale Directory Accounts
 - 2.14.5 Federal Zero Trust Strategy:
 - 2.14.5.1 Offensive: Find and Exploit Legacy Systems Exempted From Zero Trust
 - 2.14.5.2 Defensive: Dismantle Blanket Network Trust Models
 - 2.14.6 Executive-Level Cybersecurity Accountability: Forcing Organizational Penalties for Directory Failures to Ensure Leadership Actively Funds Proactive Red and Purple Team Operations
 - 2.14.7 Influence on Agency Identity Architecture: How Top-Level White House Mandates Reshape Daily Access Control Spaces in Defense Networks
- 2.15 National Institute of Standards and Technology (NIST)
 - 2.15.1 NIST's Role in Federal Cybersecurity: Reverse Engineering Standardized Cryptographic Guidelines to Find Processing Flaws and Applying Scientific Baselines to Secure Data
 - 2.15.2 Development of Security Standards and Guidelines for Federal Information

Systems (FIS): Finding Implementation Deviations From Standard Non-Military System Guidelines to Execute Targeted Exploit Attacks

2.15.3 NIST Special Publications (SPs): Guidance to Identify Exploitation of Static Risk Assessment Timelines by Using Continuous Risk Frameworks to Detect Near-Real-Time Active Directory-Related Anomalies

2.15.4 NIST Cybersecurity Framework (NIST CSF): Mapping Active Directory Attacker Tactics, Techniques, and Procedures (TTPs) Directly Against the Core Pillars of Identify, Protect, Detect, Respond, and Recover

2.15.5 NIST Digital Identity Guidance:

2.15.5.1 Offensive: Attacking Authentication Flows at Low Identity Assurance Levels (IAL)

2.15.5.2 Defensive: Enforce Maximum Authenticator Assurance Levels (AAL3) to Block Remote Exploits

2.15.6 Security Control Development, and Security Testing and Evaluation (ST&E):

2.15.6.1 Offensive: Evade Standard Validation Probing Techniques

2.15.6.2 Defensive: Execute Realistic, Adversarial-Style Evaluations Against Directory Environments

2.15.7 NIST's Influence on Active Directory Engineering Decision Making: Leveraging NIST Guidance to Mandate Multi-Forest Isolation and Defensive Boundary Design

2.16 Cybersecurity and Infrastructure Security Agency (CISA)

2.16.1 CISA's Federal Cybersecurity Mission: How Attackers Overwhelm CISA's Civilian Agency Monitoring Capabilities Through Rapid, Distributed Identity Attacks

2.16.2 Protection of Federal Civilian Executive Branch Systems: Targeting Vulnerabilities Unique to Civilian Infrastructure by Utilizing CISA Specialized Security Blueprints to Shield Directory Services From Attacks

2.16.3 Binding Operational Directives (BODs): Racing Against Defender Patching Timelines Triggered by Urgent, Mandatory Information Assurance Alert (IAVA) Remediation Orders

2.16.4 Known Exploited Vulnerabilities (KEV) Program: Using Public KEV Notices as an Immediate Offensive Roadmap to Strike Unpatched Directory Servers Before the Deadline

2.16.5 Federal Incident Reporting Requirements: Executing Gast, Automated Attack Playbooks to Achieve Objectives Before Mandatory Timelines Trigger Response Forces

2.16.6 CISA Guidance for Identity Security: Finding Flaws in Generalized Identity Security Documentation to Construct Customized Evasion Techniques Versus Deploying CISA Active Directory Toolkits

2.16.7 CISA's Role in Federal Active Directory Defense: Circumventing Centralized Continuous Diagnostics Scanning Versus Using Active Telemetry to Block Malicious Domain Modifications

2.17 Department of Defense (DoD) Cybersecurity Governance

2.17.1 Department of Defense Cybersecurity Structure: Targeting Communication Seams Between Service Branches During Joint-Force Operations Versus Executing Coordinated Defensive Responses

2.17.2 Office of the DoD Chief Information Officer (DoD CIO): Finding Policy Exceptions in Global Military Enterprise Communications to Exploit Forgotten Network Nodes

2.17.3 DoD Cybersecurity Policy and Procedures Development: Exploiting Execution Delays in Department of Defense Instructions (DoDI 8500.01) and Directives (DoDD

8570.01 / DoDD 8140) to Target Non-Hardened Administrative Procedures

2.17.4 DoD Information Enterprise Architecture: Mapping Structural Similarities Across Joint-Warfighting Networks to Replicate Successful Identity Exploits Across Multiple Bases

2.17.5 Cyber Workforce Responsibilities:

2.17.5.1 Offensive: How Attackers Target Untrained, Junior Administrative Staff for Initial Credential Harvesting

2.17.5.2 Defensive: Enforce Advanced Directory Security Training for All Systems Personnel

2.17.6 Identity and Access Management Governance Within DoD Enclaves:

2.17.6.1 Offensive: Bypass Custom Military Authentication Controls

2.17.6.2 Defensive: Enforce Strict Network Segregation Across Highly Classified Network Enclaves

2.17.7 Influence on Active Directory and FICAM Programs: How Military Instructions Dictate Defensive Forest Segregation Styles and Command Boundary Access Controls

2.18 Defense Information Systems Agency (DISA)

2.18.1 DISA's Role in Federal Cybersecurity: Attempting to Intercept or Manipulate Centralized Military Communications Traffic Before It Reaches DISA Security Backbones

2.18.2 Security Technical Implementation Guides (STIGs): Exploiting the "Compliance Blind Spot;" Blending Into Predictable, STIG-Compliant Configurations to Avoid Detection While Executing Post-Exploitation Steps

2.18.3 Security Requirements Guides (SRGs): Pinpointing Structural Gaps in High-Level Technology Family Baselines Before Specific Software Updates Deploy

2.18.4 Secure Configuration Baselines: Developing Exploit Payloads Designed to Bypass Standardized, Pre-Hardened Operating System (OS) Configurations

2.18.5 Compliance Validation and Assessment Support: Triggering False Compliance Indicators to Pass Command Readiness Inspections While Maintaining a Hidden Active Directory Foothold

2.18.6 Enterprise Services and Shared Security Infrastructure: Attacking a Single Shared Authentication Pipeline to Compromise Multiple Down-Stream Military Enclaves

2.18.7 How DISA Guidance Shapes Federal and Military Active Directory Security: Turning Raw DISA Security Checklists Into Active, Hardened, and Highly Defensible Production Domain Controllers

2.19 National Security Agency (NSA)

2.19.1 NSA's Cybersecurity Mission and Statement: Attempting to Reverse Engineer State-Level Systems Cryptography Protection Models to Break Identity Protocols

2.19.2 National Security Systems (NSS) Guidance: Finding Structural Gaps in Committee on National Security Systems Instructions (CNSSI) and Directives (CNSI) to Target Top-Tier National Intelligence Assets

2.19.3 NSA Hardening Guidance: Testing Advanced Penetration Techniques Against Specialized NSA Defensive Blueprints to Uncover Zero-Day Flaws

2.19.4 Identity Security Recommendations: Attempting to Crack Cryptographically Backed Authentication Algorithms via Advanced Compute Systems Versus Using NSA Recommendations to Eliminate Password Reliance

2.19.5 Privileged Access Security Governance:

2.19.5.1 Offensive: Subvert Administrative Separation Lines to Pivot From Low-Tiered Endpoints to High-Tiered Consoles

- 2.19.5.2 Defensive: Enforce Strict Clean-Sourced Principles
- 2.19.6 Zero Trust and Directory-Focused Security Initiatives: Evading Real-World Zero Trust Policy Boundaries by Hijacking Authenticated Hardware Signals
- 2.19.7 NSA Contributions to Federal and Military Identity Security: Operationalizing Elite Threat Intelligence Insights to Neutralize Nation-State Directory Tampering Patterns
- 2.20 United States Cyber Command (USCYBERCOM) and Defensive Cyber Operations
 - 2.20.1 United States Cyber Command (USCYBERCOM) Overview: Analyzing How Global Military Cyber Forces Project Power to Disrupt Adversary Infrastructure Before it Strikes Federal Networks
 - 2.20.2 Defensive Cyber Operations (DCO): Evading Active Threat-Hunting Teams Inside Protected Military Perimeters by Mimicking Legitimate System Administrative Behaviors
 - 2.20.3 Offensive Cyber Operations (OCO): Identifying and Neutralizing Foreign Nation-State Identity Servers to Degrade Hostile Command and Control (C2) Capabilities
 - 2.20.4 Cyber Mission Forces: Outmaneuvering Rapidly Deployed Cyber Protection Teams Sent to Reinforce Compromised or High-Risk Military Directories
 - 2.20.5 Protection of Critical Cyber Terrain: Prioritizing Authentication Infrastructure as a High-Value Operational Objective Vital to Warfighting Capabilities
 - 2.20.6 Operational Relevance of Identity Infrastructure: Treating Directory Domains as Active Weapon System Components That Dictate the Availability of Combat Operations
 - 2.20.7 Identity Systems as Operational Objectives: Maintaining a Hidden Foothold in the User Database to Control the Battlespace Throughout Long-Term Network Persistence and Attack Engagements
- 2.21 Joint Force Headquarters-Department of Defense Information Network (JFHQ-DoDIN)
 - 2.21.1 Mission and Responsibilities: Strategic Mandate of JFHQ-DoDIN as the Primary Defender of Military Networks
 - 2.21.2 DoDIN Operations: Enforcing Configuration Baselines to Starve Attacker Living-Off-The-Land (LOTL) Tactics
 - 2.21.3 Operational Readiness Assessments: Shifting from Passive Compliance Checklists to Active Red Team Breach & Adversarial Simulation (BAS)
 - 2.21.4 Cyber Operational Readiness Assessment (CORA): Evaluating Identity Enclave Survival Against Modern Tradecraft
 - 2.21.5 Cyber Readiness Metrics: Quantifying Mean Time to Remediate (MTTR), Privileged Account Drift, and Authentication Anomalies.
 - 2.21.6 Enterprise Vulnerability and Patch Management Cadence: The Race Against Time – Rapid Patch Deployment Versus N-Day Exploit Weaponization
 - 2.21.7 Identity Infrastructure and DoDIN Defense: Securing Domain Controllers as High-Value Tier 0 Tactical Assets
- 2.22 Federal Identity Governance and FICAM Authorities
 - 2.22.1 Origins of Federal Identity Governance: HSPD-12, FIPS 201, and Neutralizing Credential Stuffing via PIV/CAC Hardware Roots
 - 2.22.2 Federal ICAM Roadmaps: Deprecating Password-Reliant Identity Siloes in Favor

of the NIST SP 800-63 Digital Assurances

2.22.3 FICAM Governance Structure: How the Federal CIO Council and GSA Use FISMA to Mandate Enterprise Identity Boundaries

2.22.4 Identity Lifecycle Governance: Weaponizing Automated Provisioning and Immediate Deprovisioning to Prevent Orphaned Account Takeovers

2.22.5 Credential Lifecycle Governance: Token Issuance Controls, Hardened Certificate Revocation Lists, and OCSP Enforcements

2.22.6 Federation Governance: Securing Cross-Agency SAML and OIDC Metadata Exchanges Against Trust Interception Attacks

2.22.7 Trust Framework Governance: Validating External Identity Providers (IdPs) via Matching Authenticator Assurance Levels (AAL)

2.22.8 How Governance Influences Federal and Military Active Directory Architecture: Hardening User Attributes and Enforcing SMARTCARD_REQUIRED to Neutralize Mimikatz, Impacket, and Rubeus Post-Exploitation Frameworks

2.23 FedRAMP and Cloud Identity Governance

2.23.1 Origins of FedRAMP: Standardizing Off-Premises Security Assurances for Commercial Cloud Service Offerings (CSOs)

2.23.2 Authorization Requirements: Mapping Low, Moderate, and High Baselines to NIST SP 800-53 Technical Verification Steps

2.23.3 Shared Responsibility Model: Securing the Identity Boundary Across Infrastructure Demarcations (Cloud Provider vs. Defense Consumer)

2.23.4 Cloud Identity Security: Mandating Phishing-Resistant MFA and Banning Weak, Intercept-Prone Validation Paths

2.23.5 Hybrid Identity Considerations: Protecting Sync Pipelines Bridging Local Active Directory Domain Services (AD DS) and Microsoft Entra ID for Government.

2.23.6 Cloud Federation Challenges: The Golden SAML Threat Vector – How Token Forgery Bypasses Local AD and How to Decouple Cloud Roots

2.23.7 FedRAMP Implications for Federal and Military Active Directory and Entra ID Environments: Enforcing Tenant Restrictions, Cross-Tenant Access Policies, and Disabling Vulnerable Cloud-to-On-Premises Writebacks

2.24 Defense Industrial Base (DIB) and Cybersecurity Maturity Model Certification (CMMC)

2.24.1 Defense Industrial Base (DIB) and Cybersecurity Requirements: DFARS Clause 252.204-7012 and Combating Nation-State Targeting of Contractors

2.24.2 Controlled Unclassified Information (CUI): Defining, Classifying, and Isolating Sensitive Non-Classified Defense Assets Within Corporate Data Ecosystems

2.24.3 The NIST SP 800-171: Implementing the 100 Foundational Identity and Access Practices Across 14 Control Families

2.24.4 Cybersecurity Maturity Model Certification (CMMC): Moving From Level 1 Self-Attestation to Level 2/3 Rigorous Third-Party Audits (C3PAO)

2.24.5 Contractor Identity Management Requirements: Eliminating Shared Accounts and Enforcing Strict Accountability for System Processes and Interactive Users

2.24.6 Supply Chain Identity and Risk Management: Governing Upstream Identity Policy Flow-Down to Mitigate Subcontractor Entry Points

2.24.7 Federal and Military Active Directory Security Considerations for Contractors and Third Parties: Blocking Corporate-to-CUI Lateral Movement via Enclave Isolation, 5-Attempt Lockout Bounds, and 15-Minute Session Timeouts

- 2.25 From Policy to Technical Control: How Governance Influences Federal and Military Active Directory Security
 - 2.25.1 Laws: Establishing Statutory and Legal Accountability via FISMA and National Defense Authorization Acts (NDAA)
 - 2.25.2 Policies and Procedures: Translating Directives like OMB Memo M-22-09 and DoDI 8500.01 into Concrete Zero Trust Operational Objectives
 - 2.25.3 Standards: Codifying Cryptographic Rules via FIPS and Architectural Digital Identity Baselines via the NIST SP 800-63 Series
 - 2.25.4 Frameworks: Operationalizing the Risk Management Framework (RMF / NIST SP 800-37) to Build Security Throughout the System Lifecycle
 - 2.25.5 Security Controls: Selecting Tactical Rulesets from the NIST SP 800-53 Catalog to Govern Identification, Authentication, and Access Control
 - 2.25.6 Technical Implementations: The Engineering Plane—Converting Policy Directives into Enforceable Server Configurations, Registry Modifications, and Code
 - 2.25.7 Active Directory Security Baselines: Weaponizing the DISA Active Directory Domain Controller Security Technical Implementation Guide (STIG)
 - 2.25.8 Identity Security Enforcement Mechanisms: Deploying Host Assessment Tools (HAT), Security Scanners, and Automated SIEM Audit Parsing to Prevent Configuration Drift
 - 2.25.9 Governance-to-Configuration Traceability Matrix: Direct Cross-Referencing Blueprint Tracing Federal Law Down to Active Directory Group Policy Target Fields

- 2.26 Case Study: How a Federal Cybersecurity Requirement Becomes an Active Directory Security Control
 - 2.26.1 Executive Requirements Issued: The Catalyst—White House Executive Order Outlaws Phishable Authentication Across Federal Networks
 - 2.26.2 Policy, Procedures, and Standards Development and Interpretation: OMB and DoD CIO Translate the Mandate into Binding Operational Instructions
 - 2.26.3 NIST Guidance Creation: NIST Updates SP 800-63B to Isolate Hardened Authenticator Assurance Level 3 (AAL3) Requirements
 - 2.26.4 Risk Management Framework (RMF) Control Selection and the NIST SP 800-37, Revision 2: System Authorizing Officials Select Control IA-2 (8) to Mandate Replay-Resistant Authentication Exchange Architecture
 - 2.26.5 STIG and Technical Baseline Development: DISA Updates the Windows Server STIG to Mandate Kerberos Armoring to Block On-Path Pre-Authentication Exploits
 - 2.26.6 Active Directory Engineering Implementation: Deploying a Group Policy Object to Enforce Kerberos FAST Across the Domain Controllers Organizational Unit (OU)
 - 2.26.7 Assessment and Validation: Auditing Registry Settings and System Configurations via the Automated SCAP Compliance Checker
 - 2.26.8 Continuous Monitoring (ConMon), Logging, and Compliance Reporting Schedules: Configuring SIEM Telemetry to Track Kerberos Event ID 4768 and Reporting Live Compliance Status to the CISO Dashboard
 - 2.26.9 Lessons Learned: Why Engineering Automation, Downstream Legacy Compatibility Testing, and Continuous Log Visibility Outrank Static Administrative Sign-Off

PART I - FOUNDATIONS

Chapter 3. Applying the Risk Management Framework (RMF) and Identity-Centric Security Engineering for Federal and Military Active Directory Environments

- 3.1 Introduction
 - 3.1.1 Chapter Objectives

- 3.1.2 Why Risk Management Framework (RMF) Matters for Identity Security
- 3.1.3 Relationship Between FICAM and RMF
- 3.2 Foundations of Federal Risk Management
 - 3.2.1 Understanding Cybersecurity Risk
 - 3.2.2 Threat, Vulnerabilities, and Impact
 - 3.2.3 Risk Tolerance, Risk Appetite, and Risk Acceptance
 - 3.2.4 Enterprise Risk Management Principles
- 3.3 NIST Risk Management Framework Overview
 - 3.3.1 Origins of the Risk Management Framework (RMF)
 - 3.3.2 RMF Governance Structure
 - 3.3.3 RMF Roles and Responsibilities
 - 3.3.4 RMF and Federal Compliance Programs
- 3.4 RMF Step One: Prepare
 - 3.4.1 Command and Combatant Preparation
 - 3.4.2 Information System and Domain Asset Preparation
 - 3.4.3 Preparing Identity Infrastructure for RMF Integration
- 3.5 RMF Step Two: Categorize
 - 3.5.1 FIPS 199 Security Categorization Guidance
 - 3.5.2 Confidentiality, Integrity, and Availability – The C.I.A. Triad
 - 3.5.3 Categorizing Active Directory Assets
 - 3.5.4 Categorizing Identity Services
- 3.6 RMF Step Three: Select
 - 3.6.1 Security Control Baselines
 - 3.6.2 Selecting Identity Security Controls
 - 3.6.3 Overlay Considerations
 - 3.6.4 Security Control Tailoring
- 3.7 RMF Step Four: Implement
 - 3.7.1 Security Control Implementation Strategies
 - 3.7.2 Identity Management Controls
 - 3.7.3 Privileged Access Controls
 - 3.7.4 Federation Controls
- 3.8 RMF Step Five: Assess
 - 3.8.1 Security Control Assessment Process
 - 3.8.2 Assessment Procedures
 - 3.8.3 Evidence and Artifact Collection
 - 3.8.4 Findings and Deficiencies
- 3.9 RMF Step Six: Authorize
 - 3.9.1 Assessment Authorization Packages
 - 3.9.2 Authorizing Official (AO) Official Decisions
 - 3.9.3 Authority to Operate (ATO) Lifecycle
- 3.10 RMF Step Seven: Monitor
 - 3.10.1 Continuous Monitoring (ConMon) Fundamentals
 - 3.10.2 Identity Monitoring Requirements
 - 3.10.3 Security Control Effectiveness
 - 3.10.4 Ongoing Authorization
- 3.11 Applying the Risk Management Framework (RMF) to Active Directory
 - 3.11.1 Domain Controllers (DCs) as Critical Assets
 - 3.11.2 Identity Infrastructure Risk Assessment
 - 3.11.3 Directory Services Security Controls
 - 3.11.4 Authentication Risk Management

- 3.11.5 Privileged Access Risk Management
- 3.12 Risk Management Framework Artifacts and Documentation
 - 3.12.1 System Security Plans (SSPs)
 - 3.12.2 Security Assessment Reports (SARs)
 - 3.12.3 Risk Assessment Reports (RARs)
 - 3.12.4 Plans of Action and Milestones (POA&Ms)
 - 3.12.5 eMASS Integration
- 3.13 Chapter Summary
 - 3.13.1 Key Concepts Reviewed
 - 3.13.2 RMF-to-STIG Relationship
 - 3.13.3 Preparing for Technical Control Enforcement
- ***
- 3.13.4 From DITSCAP to DIACAP to RMF: Tracing Legacy Certification Pipelines to Modern Lifecycle Risk Frameworks
- 3.13.5 Why RMF Replaced Earlier Certification and Accreditation (C&A) Models: Replacing Point-In-Time Paper Compliance with Active Technical Defense Evaluations
- 3.13.6 The Shift From Compliance-Based Security to Risk-Based Security: Moving Past Checkbox Security to Neutralize Active Living-Off-The-Land (LOTL) Adversary Tradecraft
- 3.13.7 Command and Combatant Mission Assurance and Risk-Informed Decision Making: Evaluating Directory Compromise Against Tactical Weapons Availability
- 3.13.8 Identity as a Critical Mission Dependency: Why Directory Authentication Planes Represent a Single Point of Failure for Joint-Force Operations
- 3.13.9 Why Security Engineers Uphold RMF in the Highest Importance: Bridging Abstract Risk Authorization with Daily Tier 0 Directory Object Protection
- 3.14 RMF Governance Roles and Responsibilities
 - 3.14.1 Authorizing Officials (AO): The Final Sign-Off Authority for Accepting Domain Vulnerabilities, Identity Platform Weaknesses, and Information System Residual Risk
 - 3.14.2 Security Control Assessors (SCA): Independent Technical Auditors Verifying Enterprise Integrity Using Blue Team Scanning Toolkits and Inspection Protocols
 - 3.14.3 Information System Owners (ISO): Programmatic Leaders Accountable Governing the Entire Lifecycle of an Identity Enclave
 - 3.14.4 Information Systems Security Managers (ISSM): Managers Enforcing Security Baselines Across the Organization's Enterprise Directory Topologies
 - 3.14.5 Information Systems Security Officers (ISSO): On-the-Ground Technical Compliance Enforcers Validating Daily Directory Security States
 - 3.14.6 Information Systems Security Engineers (ISSE): Architects Building Security Controls Directly Into the Active Directory Schema and Logical Layout
 - 3.14.7 Common Control Providers: Enterprise Teams Hosting Core Identity Services Inherited by Downstream Applications
 - 3.14.8 Active Directory Systems Administrators (SA) and Identity Engineers: Hand-On Engineers Implementing Technical Configurations While Managing Privileged Credential Attack Surfaces
 - 3.14.9 Cybersecurity Service Providers and Defensive Operations Teams: SOC and Blue Team Operators Monitoring Identity Boundaries for Active Exploitation Signatures
 - 3.14.10 Mission Owners and Operational Stakeholders: End-Users and Military Leadership Whose Operational Capabilities Depend on Directory Confidentiality, Integrity, and Availability

3.15 Identity Systems as Common Control Providers

3.15.1 Understanding Common Controls: Defining Security Capabilities Implemented Once and Inherited by Thousands of Information Systems Across an Enclave

3.15.2 Enterprise Active Directory as a Shared Security Service Platform: How Central AD Architecture Serves as the Primary Security Root of Trust for Defense Enclaves

3.15.3 Authentication Services as Common Controls: Providing Centralized Kerberos Smart Card Validation Services to Eradicate Local, Phish-Prone Password Entry Points

3.15.4 Authorization Services as Common Controls: Governing Application Token Privileges via Domain Groups to Block Unauthorized Lateral Access

3.15.5 Public Key Infrastructure (PKI) and Active Directory Certificate Services (AD CS) Services as Common Controls: Hosting Enterprise Certificate Authorities (CAs) to Validate Client Identities While Exposing an Attack Surface to Asymmetric Certificate Forging

3.15.6 Active Directory Federation Services (AD FS) as Common Controls: Managing Cross-Boundary Authentication Bridges That Handle Highly Targeted SAML Token-Signing Assets

3.15.7 Inherited Controls and Authorization Boundary Dependencies: How an Exploitation Event at the Shared Identity Provider (IdP) Level Automatically Compromises All Downstream Applications

3.15.8 Common Control Provider Risk and Vulnerability Considerations: Securing Tier 0 Shared Infrastructure to Mitigate Single Point-of-Failure Compromise Vectors

3.16 RMF Step One: Categorize Federal Information Systems (FIS)

3.16.1 FIPS 199 Security Categorization: Defining Macro Security Parameters for Organizational Identity Platforms

3.16.2 The CIA Triad and Risk Management Framework (RMF) Impact Levels: Quantifying Organizational Damage if Identity Components Are Actively Exploited

3.16.2.1 Confidentiality Impact Levels: Systemic Damage Following Bulk Hash Extraction via Malicious NTDS.dit Volume Shadow Copy (VSS) Theft

3.16.2.2 Integrity Impact Levels: Impact of an Adversary Injecting Unauthorized Rogue SIDs and Backdoor Schema Modifications

3.16.2.3 Availability Impact Levels: Impact of an Identity-Targeted Ransomware Attack and KDC Service Denial Attacks Targeting Combat Information Systems

3.16.3 Categorizing Identity Infrastructure Components: Why Domain Controllers Automatically Default to a High-Impact Categorization Baseline

3.16.4 Mission Impact of Active Directory Component Failure: Tracing Kerberos Infrastructure Faults to Immediate Cross-Enclave Communications Blackout States

3.16.5 Categorizing Shared Authentication Services: Setting Rigorous Assurance Parameters for Authentication Boundaries to Protect Identity Pipelines Feeding Weapon and Intelligence Platforms

3.16.6 Case Study: Categorizing Military Identity Infrastructure: Establishing a FIPS 199 Baseline for a Multi-Branch Joint-Force Theatre Deployment

3.17 RMF Step Two: Security Control Selection Process

3.17.1 NIST SP 800-53 Security Controls Families: Navigating the Massive Catalog of Federal Safeguards to Secure Identity Data

3.17.2 Baseline Selection: Applying the High-Impact Control Allocation Baseline to

Protect Tier 0 Directory Infrastructure

3.17.3 Control Overlaying Concepts: Tailoring Standard Security Baselines with Specialized Rules Specifically Designed for Military Directory Boundaries

3.17.4 National Security Systems (NSS) Considerations: Applying CNSSI 1253 Parameters to Adjust Security Controls for Classified Identity Data Spaces

3.17.5 Identity and Authentication (IA) Control Families: Isolating Specific Controls Governing Multi-Factor Validation and Cryptographic Authenticators

3.17.6 Access Control (AC) Families: Selecting Rules to Govern the Principle of Least Privilege and Block Unauthorized Directory Tree Exploitation

3.17.7 Audit and Accountability (AA) Families: Allocating Logging Rules to Capture Security Event Logs and Track Lateral Movements

3.17.8 Configuration Management (CM) Families: Mandating Strict Software and System Configuration Baselines to Prevent Administrative Configuration Drift

3.17.9 Security Control Tailoring and Risk Acceptance: Documenting Technical Adjustments When Strict Compliance Conflicts with Unique Tactical Field Constraints

3.18 RMF Step Three: Implementing Identity-Centric Security Controls

3.18.1 Implementing Authentication Controls: Enforcing Kerberos PKINIT and Disabling NTLM to Stop Pass-the-Hash (PtH) Attacks

3.18.2 Implementing Authorization Controls Through Group Memberships and Access Control Lists (ACLs): Hardening Domain Object ACLs to Stop DACL Abuse and Unauthorized Security Group Modifications

3.18.3 Implementing Public Key Infrastructure (PKI) Controls via Active Directory Certificate Services (AD CS): Hardening Certificate Templates to Block ESC1 Through ESC8 Domain Escalation Methodologies

3.18.4 Implementing Federation Controls via Active Directory Federation Services (AD FS): Isolating Token-Signing Private Keys From General Local Server Administrators to Block Golden SAML Creation

3.18.5 Implementing Privileged Access Controls: Deploying an ESAE Administrative Forest Design Pattern to Separate Administrative Identities From Everyday Internet Enclaves

3.18.6 Implementing Audit Controls: Configuring Advanced Security Audit Policies to Capture Kerberos Ticket Requests and Privilege Use

3.18.7 Implementing Configuration Change Management Controls: Using Group Policy Object (GPO) Locking Mechanism to Enforce Desired-State Baselines Globally

3.18.8 Mapping Security Controls to Production Active Directory Configurations: Translating Text-Based NIST Requirements Into Enforceable Production Registry Keys and System Settings

3.19 RMF Step Four: Assessing Identity Security Controls

3.19.1 Security Control Assessment Methodologies: Combining Technical Scanning, Manual Code Review, and Configuration Interview to Evaluate Directory Security

3.19.2 Reviewing Active Directory Secure Configurations: Using Automated Tools to Identify Domain Administrative Trust Blind Spots and Orphaned High-Value Objects

3.19.3 Evaluating Authentication Mechanisms: Testing the Domain Boundary to Verify the Total Eradication of Weak, Phish-Prone Fallback Pathways

3.19.4 Assessing PKI Implementations: Auditing AD CS Templates for Malicious Configurations Using Automated Validation Scanners

3.19.5 Assessing Federation Architecture: Reviewing Claims Provider Trusts to Identify Vulnerabilities to External Token Manipulation

3.19.6 Reviewing Administrative Access Models: Analyzing Attack Pathways Using Graph-Theory Scanners to Locate Latent Tier 0 Privilege Escalation Routes
3.19.7 Identifying Identity-Centric Security Weaknesses, Flaws, and Gaps: Documenting Structural Design Oversights That Bypass Traditional Compliance Scanners
3.19.8 Common Assessment Findings Within Federal and Military Active Directory Environments: Deconstructing Recurring Vulnerability Trends Discovered During Joint-Cyber Inspection Regimes

3.20 RMF Step Five: Authorizing Risk

3.20.1 Understanding Authorization Decision Making: Weighing Technical Active Directory Exploitation Paths Against Vital Mission Requirements

3.20.1.1 Authorization to Operate (ATO) Decisions: Granting Full System Access When the Directory Layer Proves Resilient to Standard Adversary Toolsets

3.20.1.2 Interim Authorization to Operate (IATO) Decisions: Awarding Temporary Operational Status Under Strict, Timed Technical Remediation Bounds

3.20.1.3 Denial of Authorization to Operate (DATO) Decisions: Shutting Down Directory Operations Due to Fatal, Unmitigated Tier 0 Architectural Gaps

3.20.2 Residual Risk Analysis: Calculating the Threat Surface Remaining in the Directory Environment After Applying All Defensive Security Controls

3.20.3 Identity-Related Risks That Concern Authorizing Officials: Mapping Hidden Transitive Across-Trust Risks and Blind Spots in Authentication Auditing Streams

3.20.4 Mission Impact and Risk Acceptance: The Strategic Compromise – Fomrally Accepting Local Directory Vulnerabilities to Sustain Critical Field Combat Operations

3.20.5 Case Study: Authorization Decisions Following Identity Assessment Findings: Walkthrough of an AO Negotiating Risk Acceptance Rules After Discovering Systemic DACL Flaws on Domain Controllers

3.21 RMF Step Six: Continuous Monitoring of Federal and Military Identity Infrastructure

3.21.1 Continuous Monitoring Strategy Development: Moving Beyond Periodic Audits to Construct a Real-Time Identity Telemetry and Threat Detection Loop

3.21.2 Active Directory Security Monitoring: Ingesting Replication and Attribute Telemetry to Detect Unauthorized Schema Backdoors and DCSync Behaviors

3.21.3 Authentication Process Monitoring: Tracking Anomalous TGT/ST Requests to Alert on Golden Ticket, Silver Ticket, and AS-REP Roasting Indicators

3.21.4 Privileged Access Monitoring: Enforcing Instant, Zero Delay Alarms on Additions to Tier 0 Domain Groups (Domain Admins, Enterprise Admins, Built-In Administrators)

3.21.5 PKI Monitoring: Real-Time Parsing of Certificate Authority (CA) Issuance Events to Detect Rogue Certificate Registrations Against High-Value Accounts

3.21.6 Federation Monitoring: Analyzing AD FS Proxy Traffic to Capture Inbound Claims Forgeries and Anomalous Federated Identity Movements

3.21.7 Vulnerability Monitoring: Implementing Automated Scanners to Flag Unpatched Domain Controller Software Vulnerabilities Within Hours of RTW (Release to World)

3.21.8 Configuration Drift Monitoring: Deploying Desired-State Checks to Automatically Detect and Revert Local Group Policy Misconfigurations Attempted by Rogue Administrators

3.21.9 Reporting Continuous Monitoring Results: Feeding Dynamic Directory Risk Ratings Into Executive SIEM Dashboards for Instant CISO and Operational Visibility

3.22 Identity-Centric Risk Management

- 3.22.1 Domain and Information Systems (IS) Authentication Risk: Mitigating Password-Spraying and Brute-Force Exploits by Hardening Kerberos and Exterminating Legacy Dialects
- 3.22.2 Domain and Information Systems (IS) Authorization Risk: Neutralizing Account Takeover Vectors by Hardening Delegated Administrative Boundaries and Object Permissions
- 3.22.3 Domain Credential Risk: Blocking Mimikatz LSASS Harvesting and Pass-the-Ticket (PtT) Attacks via Windows Credential Guard and Protected Users Groups
- 3.22.4 Domain Federation Risk: Securing Inter-Enclave Bridges Against Cloud-Pivoting Attacks and SAML Signing Certificate Compromises
- 3.22.5 Domain Privileged Access Risk: Eliminating Administrative Host Contamination via Dedicated Privileged Access Workstations (PAWs) and Clean-Source Pipelines
- 3.22.6 Domain Certificate Trust Risk: Hardening Enterprise CA Certificate Infrastructures to Prevent Arbitrary Domain Admin Certificate Generation
- 3.22.7 Domain Replication Risk: Monitoring Access Rights to Block Unauthorized DCSync Directory Replication Attacks
- 3.22.8 Hybrid Domain Identity Risk: Preventing Lateral Cloud-to-On-Premises Pivots by Securing Identity Synchronizer Hubs and Restricting Cloud Directory Writebacks
- 3.22.9 Supply Chain Identity Risk: Mitigating External Entry Points by Securing Trust Relationships and Restricting Third-Party Contractor Account Rights

3.23 Common RMF Findings in Federal and Military Active Directory Environments

- 3.23.1 Legacy Authentication Protocols: The Danger of Leaving NTLMv1, WDigest, and LLMNR Active to Accommodate Outdated Weapon Systems
- 3.23.2 Weak Administrative Network Separation and Segmentation: Allowing Tier 0 Domain Administrators to Authenticate From Insecure, Phish-Prone User Subnets
- 3.23.3 Excessive Privileges and Permissions Creep: Cumulative Domain Group Access Assignments That Accidentally Expand an Attacker's Attack Surface
- 3.23.4 Inadequate Audit Logging Controls Configuration: Missing Subcategory Advanced Audit Flags, Leaving Incident Response Teams Blind to Account Forgeries
- 3.23.5 Insecure Active Directory Certificate Services (AD CS) and Certificate Authority (CA) Templates: Misconfigured Templates Left Open to Misuse, Leading to Domain Takeover
- 3.23.6 Federation Trust Misconfigurations: Leaving Signing Certificates Unrotated and Allowing for Weak, Broad Claims Mapping Across Tenant Boundaries
- 3.23.7 Unmanaged High-Level Service Accounts: Allowing High-Privilege Domain Accounts to Retain Static Passwords, Exposing Them to Kerberoasting Attacks
- 3.23.8 Domain Controller (DC) Replication Permission Misconfigurations: Granting Over-Privileged WriteDACL Rights to Non-Tier 0 Objects, Enabling Malicious DCSync Attacks
- 3.23.9 Failure to Implement Enterprise-Wide and Domain- and Host-Level Principle of Least Privilege (PoLP): Over-Relying on Broad Administrative Groups Instead of Granular, Role-Based Access Control (RBAC)

3.24 The Risk Management Framework (RMF) Through the Eyes of an Active Directory Security Engineer

- 3.24.1 What RMF Looks Like During Daily Operations: Converting Theoretical RMF

Governance Guidelines Into Concrete, Day-to-Day Server Engineering Steps

- 3.24.2 Translating Security Controls Into Technical Configurations: Mapping Stringent NIST Text Requirements Into Enforceable Group Policies, Registry Tweaks, and Schema Attributes
- 3.24.3 Supporting Security Control Assessments: Providing Validated System Artifacts and Evidence to Auditors Without Introducing Unintended System Exposures
- 3.24.4 Generating Assessment Risk and Vulnerability Artifacts and Evidentiary Documentation: Using Automated Tooling to Prove a Hardened Active Directory Security Baseline State During Audits
- 3.24.5 Supporting Authorizing Officials (AO) and Designated Authorizing Officials (DAO): Providing Accurate, Quantitative Technical Risk Metrics to Help Leadership Make Operationally Sound Deployment Decisions
- 3.24.6 Maintaining and Adhering to Compliance Objectives Without Sacrificing Security: Avoiding the “Compliance Trap” by Ensuring Audit Preparation Deepens True Directory Defense Postures
- 3.24.7 Balancing Command Mission Requirements and Tailored Security Requirements: Creating Rigorous Compensating Controls When Operational Realities Prevent Standard GPO Enforcements

3.25 Case Study: Applying the Risk Management Framework (RMF) to a Federal and Military Active Directory Enterprise

- 3.25.1 Federal Information System (FIS) Categorization: Setting a High-Impact Security Matrix for a Massive, Multi-Forest Combined Operations Network
- 3.25.2 Security Control Selection: Applying Customized Defensive Overlays to Mandate Phishing-Resistant Identity Tokens Across All Enterprise Layers
- 3.25.3 Active Directory Security Control implementation: Enforcing Tightened GPOs, Hardened AD CS Certificate Templates, and Disabling Legacy Protocols En Masse
- 3.25.4 Security Assessment Activities: Subjecting the Hybrid Directory Mesh to Aggressive Red Team Penetration Exploits and SCA Analysis
- 3.25.5 Authorization Decision Making Process: Evaluating Remediation Success to Secure a Formal Authority to Operate (ATO) From Command Leadership
- 3.25.6 Continuous Monitoring (ConMon) Activities: Establishing Centralized SIEM Log Ingestion and Continuous Scanning to Intercept Configuration Drift Instantly
- 3.25.7 Discovery of Identity-Related Security Findings: Spotting a Hidden, Exploitable DACL Misconfiguration on a High-Value Service Account During Operational Telemetry Audits
- 3.25.8 Remediation and POA&M Development for Risk Tracking and Command Vulnerability Accountability and Transparency: Creating a Formal Plan of Action and Milestones (POA&M) File to Legally Track the Lifecycle and Milestones of Identity Remediation and Mitigation
- 3.25.9 Lessons Learned: Why Operational Visibility, Aggressive Testing, and Engineering Automation Outrank Static Governance Paperwork During Active Combat Engagements

PART I - FOUNDATIONS

Chapter 4: Security Requirements Guides (SRGs), Security Technical Implementation Guides (STIGs), and Active Directory Compliance

- 4.1 Introduction
 - 4.1.1 Chapter Objectives
 - 4.1.2 The Role of Technical Control Enforcement

- 4.1.3 Relationship Between RMF, SRGs, and STIGs
- 4.1.4 Why Compliance Alone Is Not Security
- 4.2 Understanding DISA Security Guidance
 - 4.2.1 Origins of the STIG Program
 - 4.2.2 DISA's Role in Federal Cybersecurity
 - 4.2.3 Evolution of Security Configuration Standards
 - 4.2.4 STIGs Within the DoD Security Ecosystem
- 4.3 Security Requirements Guides (SRGs)
 - 4.3.1 What Is an SRG?
 - 4.3.2 Purpose and Scope of SRGs
 - 4.3.3 SRG Development Process
 - 4.3.4 Mapping SRGs to RMF Security Controls
 - 4.3.5 SRG Inheritance Models
 - 4.3.6 Common Federal SRGs
- 4.4 Security Technical Implementation Guides (STIGs)
 - 4.4.1 What Is a STIG?
 - 4.4.2 STIG Structure and Organization
 - 4.4.3 STIG Severity Categories
 - 4.4.4 Category I (CAT I) Findings
 - 4.4.5 Category II (CAT II) Findings
 - 4.4.6 Category III (CAT III) Findings
 - 4.4.7 Vulnerability Identifiers (V-IDs) and Rule IDs
- 4.5 STIG Lifecycle Management
 - 4.5.1 STIG Publication Process
 - 4.5.2 STIG Revisions and Updates
 - 4.5.3 Vulnerability Management and Integration
 - 4.5.4 Continuous Compliance Monitoring
 - 4.5.5 Configuration Drift Management
- 4.6 Active Directory STIG Fundamentals
 - 4.6.1 Domain Controller Security Requirements
 - 4.6.2 Forest and Domain Security Considerations
 - 4.6.3 Authentication Security Requirements
 - 4.6.4 Authorization Security Requirements
 - 4.6.5 Identity Infrastructure Hardening Principles
- 4.7 Applying STIGs to Active Directory Components
 - 4.7.1 Domain Controllers (DCs)
 - 4.7.2 Organizational Units (OUs)
 - 4.7.3 Group Policy Objects (GPOs)
 - 4.7.4 Domain Name System (DNS) Services
 - 4.7.5 Dynamic Host Configuration Protocol (DHCP) Services
 - 4.7.6 Active Directory Certificate Services (AD CS)
 - 4.7.7 Active Directory Federation Services (AD FS)
- 4.8 Group Policy as a Compliance Enforcement Mechanism
 - 4.8.1 Group Policy Object (GPO) Architecture
 - 4.8.2 Centralized Security Enforcement
 - 4.8.3 Baseline Security Template
 - 4.8.4 Administrative Template Management
 - 4.8.5 Configuration Consistency
- 4.9 Credential and Authentication Compliance
 - 4.9.1 Password Policy Requirements

- 4.9.2 Multifactor Authentication (MFA) Requirements
- 4.9.3 Smart Card Enforcement
- 4.9.4 Kerberos Security Requirements
- 4.9.5 NTLM Reduction Strategies
- 4.10 Privileged Access Compliance
 - 4.10.1 Administrative Account Requirements
 - 4.10.2 Tiered Administration Models
 - 4.10.3 Separation of Duties
 - 4.10.4 Privileged Access Workstations and Secure Administrative Workstations (PAWs & SAWs)
 - 4.10.5 Just-In-Time (JIT) Administration
- 4.11 Auditing and Logging Requirements
 - 4.11.1 Audit Policy Requirements
 - 4.11.2 Event Log Protection
 - 4.11.3 Security Monitoring Requirements
 - 4.11.4 Security Information and Event Management (SIEM) Integration
 - 4.11.5 Compliance Reporting
- 4.12 Automated Compliance Assessment
 - 4.12.1 STIG Viewer
 - 4.12.2 Security Content Automation Protocol (SCAP) Compliance Checker (SCC)
 - 4.12.3 Assured Compliance Assessment Solution (ACAS) Integration
 - 4.12.4 PowerShell-Based Validation
 - 4.12.5 Enterprise Compliance Dashboards
- 4.13 Findings, Mitigations, and Risk Acceptance
 - 4.13.1 Identifying Vulnerabilities
 - 4.13.2 Corrective Actions
 - 4.13.3 Mitigation Statements
 - 4.13.4 Risk Acceptance Procedures
 - 4.13.5 POA&M Development
- 4.14 Common Active Directory Compliance Challenges
 - 4.14.1 Legacy System Constraints
 - 4.14.2 Operational Versus Security Requirements
 - 4.14.3 Resource Limitations
 - 4.14.4 Third-Party Application Dependencies
 - 4.14.5 Maintaining Long-Term Compliance
- 4.15 Case Study: Active Directory STIG Implementation
 - 4.15.1 Initial Assessment
 - 4.15.2 Remediation Planning
 - 4.15.3 Deployment Strategy
 - 4.15.4 Validation and Verification
 - 4.15.5 Lessons Learned
- 4.16 Chapter Summary
 - 4.16.1 Key Concepts Reviewed
 - 4.16.2 Compliance-to-Assessment Transition
 - 4.16.3 Preparing for Security Assessments
 - ***
 - 4.16.4 Evolution of Federal and Military Security Configuration Standards: Tracing the Path From Legacy Local Registry Customizations to Centralized DISA Enforcement
 - 4.16.5 Origins of Security Requirements Guides (SRGs): Understanding High-Level, Vendor-Agnostic Technology Compliance Frameworks

4.16.6 Origins of Security Technical Implementation Guides (STIGs): The Transition to Product-Specific, Actionable Scripted Hardening Baselines

4.16.7 Relationship Between RMF, SRGs, and STIGs: How STIG Check and Fix Actions Directly Satisfy NIST SP 800-53 Technical Control Allocation

4.16.8 Why STIGs Exist: Eradicating Default Vendor Credentials, Vulnerable Protocols, and Loose Insecure Permissions Configurations

4.16.9 Security Standardization Across Federal and Military Enterprises: Achieving Cryptographic and Access Predictability Across Global Defense Enclaves

4.16.10 STIGs as Risk Reduction Mechanisms: Shrinking the Corporate Attack Surface to Neutralize Automated External Exploitation Scripts

4.16.11 Why STIGs Matter to Active Directory Security Engineers and Enterprise Defenders: Grounding Abstract Strategic Policies Into Actionable and Meaningful Tier 0 Operating System Adjustments

4.17 STIG Governance and Oversight

4.17.1 Defense Information Systems Agency (DISA): The Primary Author, Publisher, and Arbiter of Military Cyber Hardening Specifications

4.17.2 Department of Defense Chief Information Officer (DoD CIO): Issuing Broad Mandates Forcing Defense Components to Adhere to Mandatory DISA Standards

4.17.3 National Institute of Standards and Technology (NIST): Providing the Underlying Security Parameter Catalogs (SP 800-XX) and National Vulnerability Database (NVD) Engines

4.17.4 Federal Information Security Modernization Act (FISMA): Statutory Requirements Mandating Standardized Configuration Management and Continuous Auditing Regimes

4.17.5 Security Control Assessors (SCAs): Independent Technical Inspectors Utilizing STIG Check Procedures to Validate Network Defensive Readiness

4.17.6 Authorizing Officials (AO): Reviewing STIG Compliance Discrepancies and Open Vulnerability Metrics to Award Systems an Operational ATO

4.17.7 Information Systems Security Managers (ISSMs): Managing Component-Level Overviews of STIG Exceptions and Enterprise Risk Scorecards

4.17.8 Information Systems Security Officers (ISSOs): Executing On-the-Ground Verification of Asset Configurations and Tracking Mitigation Milestones

4.17.9 Active Directory Security Engineers and Administrators: Engineering and Deploying the Group Policies and Scripted Baselines Required to Enforce STIG Directives

4.17.10 Common Control Providers: Hosting Core STIG-Compliant Infrastructure Roles That Downstream Enclaves Inherit Automatically

4.18 Security Requirements Guides (SRGs)

4.18.1 Purpose of Security Requirements Guides: Establishing General Technical Rulesets Before Specific Product Hardening Guides are Published

4.18.2 SRG Hierarchy and Structure: Navigating the Core Demarcations Between Application, Network, and Operating System Requirements Groups

4.18.3 Mapping SRGs to NIST SP 800-53 Controls: Tracing Broad Architectural Statements Directly to Specific Identification and Authentication (IA) Objectives

4.18.4 Control Inheritance Concepts: Understanding How Multi-Tenant Cloud and Hosting Facilities Pass Down Verified SRG Criteria to Tenant Applications

4.18.5 SRGs Within RMF Authorized Environments: Utilizing General Guides to Formulate Compensating Controls When No Specific STIG Exists for a Product

- 4.18.6 Identity-Related Security Requirements: Standardizing How Digital Personas are Managed and Traced Across Heterogeneous Enclaves
- 4.18.7 Authentication Security Requirements: Establishing Rules for Enforcing Multi-Factor Hardware Validation and Rejecting Single-Factor Fallbacks
- 4.18.8 Authorization Security Requirements: Defining System Group Containment Rules to Strictly Limit the Delegation of Privilege Escalation Paths
- 4.18.9 Auditing and Accountability Requirements: Dictating What Identity Telemetry Must Be Tracked, Retained, and Forwarded to Central Defense Postures
- 4.18.10 Configuration Management Requirements: Forcing Authorized, Documented Engineering Sign-Off Prior to System Baseline Alteration

4.19 Understanding STIG Architecture and Components

- 4.19.1 STIG Rule Structure: Deconstructing the Specific Formatting of an Enforceable Technical Directive
- 4.19.2 Vulnerability Identifiers (V-IDs): Tracking Core Configuration Defects Across System Updates and Product Generations
- 4.19.3 Rule Identifiers (Rule IDs): The Discrete, Actionable Audit Unit Used by Engineers and Compliance Scanners
- 4.19.4 Security Control Correlation Identifiers (CCIs): The Precise Technical Bridge Linking a Singular STIG Rule to an Overarching NIST Control Objective
- 4.19.5 NIST SP 800-53 Control Mappings: Verifying Compliance Metrics by Matching Rule Execution Directly to Federal Management Frameworks
- 4.19.6 Vulnerability Discussions: The Analytical Text Detailing Why a Setting is Weak and How an Adversary Exploits the Unhardened State
- 4.19.7 Check Procedures: Step-by-Step Practical Testing Commands and Registry Queries to Expose an Existing Vulnerability Finding
- 4.19.8 Fix Procedures: Clear, Remedial Technical Steps, Scripts, or Policy Entries Required to Neutralize the Discovered Vulnerability
- 4.19.9 Mitigations and Risk Acceptances: Formulating Acceptable Technical Documentation of Accountability to Reduce Threat Vectors When a Direct Fix is Operationally Impossible
- 4.19.10 Severity Categories and Risk Prioritization: Using Categorization Standards to Allocate Critical Engineering Response Capabilities Efficiently

4.20 CAT I, CAT II, and CAT III Findings

- 4.20.1 Understanding Severity Classifications: Analyzing the Spectrum of Technical Vulnerabilities Based on Immediate Exploitation Viability
- 4.20.2 CAT I Findings: Critical Flaws Allowing Immediate, Direct, Unauthenticated System Exploitation or Complete Root Identity Takeovers
- 4.20.3 CAT II Findings: High-to-Medium Vulnerabilities That Degrade Information Assurances or Provide Intermediary Footholds for Adversary Pivoting
- 4.20.4 CAT III Findings: Lower-Impact Degradations of Administrative Rigor That Weaken Auditing or Complicate Enterprise Change Tracking Over Time
- 4.20.5 Mission Impact of STIG Findings: Mapping Active Unmitigated Discrepancies Directly to Increased Risk of Command-and-Control Denial of Service (DoS)
- 4.20.6 Risk Acceptance Considerations: Evaluating the Operational Necessities of a Critical Application Against the Risk of Holding Open a Fatal CAT I Entry Point
- 4.20.7 POA&M Development Requirements: Constructing Standardized Plans of Action and Milestones Documents to Legally Track Overdue Vulnerability Hardening and Accountability

4.21 Applying STIGs to Active Directory Environments

- 4.21.1 Active Directory as a Security Control Provider: Forcing the Central Domain Infrastructure to Push Secure System Behaviors Globally
- 4.21.2 Domain Controller Security Baselines: Applying Rigid OS and Service Configurations to Prevent Direct Memory Parsing and SAM/NTDS.dit Theft
- 4.21.3 PAW and SAW Baselines: Implementing PAW and SAW STIGs to Block Tier 2 to Tier 0 Credential Contaminations
- 4.21.4 Active Directory Organizational Unit (OU) Security: Securing Container Access and Disabling Insecure Inheritances to Block Adversary DACL Overtakes and Modifications
- 4.21.5 Group Policy Security Configuration Requirements: Restricting GPO Modification Permissions to Block Malicious Group Policy Object Injection Attacks
- 4.21.6 Active Directory Trust Security Requirements: Enforcing SID Filtering and Selective Authentication to Confine Cross-Boundary Identity Hops
- 4.21.7 LDAP and LDAPS Security Requirements: Disabling Cleartext Simple Binds and Mandating Signed/Encrypted LDAP Channel Binding to Defeat Sniffing and Relay Vectors
- 4.21.8 Kerberos Security Configuration Requirements: Hardening Ticket Lifetimes, Disabling Weak DES/RC4 Encryption, and Enforcing AES256-HMAC Standards
- 4.21.9 NTLM Reduction and Elimination Strategies: Using Group Policies to Track NTLM Audits, Restrict Outbound Egress Network Traffic, and Prevent NTLM Relay Exploitation Attacks
- 4.21.10 Active Directory Replication Security Requirements: Restricting Access Rights to Prevent Unauthorized DCSync Commands From Harvesting Domain Hashes

4.22 Implementing Identity-Centric Security Controls Through STIGs

- 4.22.1 Authentication Controls: Hardening Domain Settings to Force Cryptographic Smartcard Enforcement (SMARTCARD_ENFORCEMENT) and Randomize Local Administrator Passwords Using LAPS
- 4.22.2 Authorization Controls: Restricting Access Rights Like SeEnableDelegationPrivilege to Stop Arbitrary Resource-Based Constrained Delegation (RBCD) Manipulation
- 4.22.3 Privileged Access Controls: Confining Administrative Accounts and Deploying Restrictive Group Policies via Windows Protected Users Security Grouping
- 4.22.4 Account Management Controls: Hardening Parameters Governing Inactive Account Expiration, Password Complexity, and Disabling Legacy Guest Default
- 4.22.5 Service Account Security Controls: Transitioning Monolithic Service Profiles Into Hardened Group Managed Service Accounts (gMSAs) to Neutralize Kerberoasting
- 4.22.6 Audit Logging Controls: Configuring Advanced Security Audit Subcategories to Log Process Creation, Directory Service Changes, and Kerberos Ticket Events
- 4.22.7 Configuration Management Controls: Deploying AppLocker, App Control, and Credential Guard via GPO to Shield System Memory from LSASS Harvesting (Mimikatz)
- 4.22.8 Remote Administration Controls: Mandating Encrypted WinRM/PS-Remoting Pipelines while Disabling Vulnerable Legacy Protocols Like Telnet or RDP over NTLM
- 4.22.9 Endpoint Security Controls: Restricting Local Administrators from Overriding Enterprise Group Policy Targets and Disabling LLMNR/NetBIOS Local Name Resolution
- 4.22.10 Hybrid Identity Security Controls: Securing Synchronization Engines, Configuring Azure AD Tenant Restrictions, and Isolating Cloud Cloud-Native Identity Infrastructure Roles

4.23 STIGs for Public Key Infrastructure (PKI) and Active Directory Certificate Services (AD CS)

4.23.1 PKI Security Foundations: Structuring Asymmetric Cryptographic Trust Frameworks Across Defense Enclaves

4.23.2 Certificate Authority Security Requirements: Applying the DISA CA STIG to Secure Offline Root CAs and Subordinate Issuing Servers

4.23.3 Certificate Lifecycle Management Requirements: Mandating Secure Cryptographic Generation and Archival Controls for Cryptographic Key Assemblies

4.23.4 Certificate Template Security Controls: Hardening Templates to Block Malicious SAN Attributes (EDITF_ATTRIBUTESUBJECTALTNAME2) and Preventing Misconfigured Certificate Takeovers (ESC1-ESC8)

4.23.5 Enrollment Security Controls: Restricting Certificate Enrollment and Auto-Enrollment Permissions Only to Authorized Device OUs and Vetted User Profiles

4.23.6 Certificate Revocation Requirements: Enforcing Continuous Publication and Low-Latency Ingestion of Validated CRL and OCSP Responder Metrics

4.23.7 Common AD CS Misconfigurations: Analyzing Flawed Template Security Settings That Allow Low-Privilege Accounts to Request Domain Admin Identity Tokens

4.23.8 Mission Impact of Certificate Authority Compromise: How a Single Forged Certificate Can Compromise an Entire Cross-Forest Smartcard Boundary

4.24 STIGs for Federation and Active Directory Federation Services (AD FS)

4.24.1 Federation Security Concepts: Managing Cross-Organization Trust Boundaries without Replicating Core Identity Directories

4.24.2 Trust Relationships and Security Requirements: Applying the ADFS STIG to Harden Relying Party Agreements and Confine Cross-Tenant Ingress Paths

4.24.3 Token Security Requirements: Securing and Rotating Private SAML Token-Signing Certificates Against Memory Harvest and Extraction Attempts

4.24.4 Claims-Based Authentication Security: Writing Strict Identity Transformations Rules to Prevent Inbound Attacker Claims Forgery and Identity Spoofing

4.24.5 AD FS Security Baselines: Deploying ADFS Web Application Proxies (WAP) in Extranet Demarcation Zones to Shield Inbound Internal Authentication Engines

4.24.6 Federation Logging Requirements: Verbose Parsing of Federation Proxy Data Logs to Spot Anomalous Cross-Boundary Identity Behavior Patterns

4.24.7 Common Federation Vulnerabilities: Analyzing how Compromised On-Premises Token Systems are Exploited to Bypass Cloud MFA in Golden SAML Scenarios

4.24.8 Mission Impact of Federation Compromise: Total Cryptographic Subversion of Multi-Tenant Federations, Leading to Downstream Resource Access Failures

4.25 Assessing STIG Compliance

4.25.1 Security Compliance Validation Methodologies: Combining Automated Assessment Scans with Expert Manual Checklist Verification Procedures

4.25.2 Security Content Automation Protocol (SCAP): Running Automated XML-Driven Configuration Scanning Software Engines to Uncover Local Registry Exceptions and Other Hidden Vulnerabilities

4.25.3 STIG Viewer: Leveraging the DISA Checklist Management Tool to Build, Review, Close, and Export System Vulnerability Validation Checklists

4.25.4 Automated Compliance Assessment Tool (ACAS): Utilizing PowerShell Desired State Configuration (DSC) and Native Security Scripts to Evaluate Domain and Asset Health

- 4.25.5 Evidence and Artifact Collection Procedure: Generating Cryptographically Non-Repudiable Evidence Logs and Artifacts to Prove Secure System Behavior to External Auditing Panels
- 4.25.6 Artifact Generation Requirements: Structuring System Configurations, Asset Reports, and Group Policy Layouts Into Verifiable Compliance Packages for eMASS
- 4.25.7 Assessor Validation Activities: Independent Auditor Processes for Revalidating and Reverifying Controls, Reviewing Logging Chains, and Spotting Forged Evidence Submissions
- 4.25.8 Remediation Verification Procedures: Validating That an Applied System Fix Completely Resolves a Discovered Exception Without Breaking Mission Functionality

- 4.26 STIG Compliance Versus Operational Security (OPSEC)
 - 4.26.1 When Compliance Does Not Equal Security: The Compliance Trap – Why a 99.7% STIG-Compliant Active Directory Domain Can Still Be Breached by Living-Off-The-Land (LOTL Attacks
 - 4.26.2 When Security Does Not Equal Compliance: Managing Situations Where Advanced Offensive Mitigations Intentionally Diverge from Standard DISA Rule Definitions
 - 4.26.3 Common Assessment Blind Spots: Understanding Why Standard STIG Scanners Fail to Detect Latent Attack Chains and Logical Permission Relationships
 - 4.26.4 Identity and Attack Paths Beyond Compliance: Using Graph-Theory Exploitation Maps (BloodHound/SharpHound) to Reveal Multi-Hop Domain Admin Escalation Vectors Hidden Within Fully Compliant Groups
 - 4.26.5 Risk-Based Security Decision Making: Transitioning Engineering Focus from Surface Checklist Elimination to Proactive Attack Path Destruction
 - 4.26.6 Balancing Mission Requirements and Security Requirements: Formulating Valid Compensating Security Controls to Preserve Vital Warfighter System Operations

- 4.27 The STIG Process Through the Eyes of an Active Directory Security Engineer
 - 4.27.1 Daily STIG Compliance Checks and Operations: Ongoing Configuration Engineering Steps with Strict Change Authorization and Maintenance Routines
 - 4.27.2 Translating STIG Findings Into Technical Remediation Activities: Breaking Down Cryptic DISA XML Rules Into Test Group Policy Object Actions and Script Deployments
 - 4.27.3 Managing Security Exceptions: Formulating and Submitting Formally Documented Technical Mitigations When Standard STIG Enforcements Crash System Operations
 - 4.27.4 Supporting Security Assessments: Defending the Active Directory Configuration Partition Against Aggressive Inspector Interrogations and Vulnerability Discrepancies
 - 4.27.5 Generating Compliance Artifacts: Automating the Assembly of Group Policy Configurations, Schema Queries, and Audit Metrics Packages
 - 4.27.6 Supporting Authorization Activities: Providing Clear Technical Explanations to Help Authorizing Officials (AOs) Accurately Appraise Identity and Information System Vulnerabilities
 - 4.27.7 Continuous Monitoring and Compliance Maintenance: Preventing Configuration Drift by Establishing Automated Alerts to Spot Local System Deviations Instantly

- 4.28 Case Study: Applying STIGs Within a Federal and Military Active Directory Enterprise
 - 4.28.1 Initial Compliance Assessment: Executing Baseline SCAP and Manual Checklist Sweeps Across a Massive Multi-Forest Defense Infrastructure Network

- 4.28.2 Discovery of Security Findings: Locating Latent CAT I Flaws, Insecure Certificate Templates, and Cleartext Protocols Left Active From Legacy Systems
- 4.28.3 Identity Infrastructure Risk Analysis: Modeling How Discovered Exceptions Interlock with Graph-Theory Attack Paths to Enable Domain Admin Takeovers
- 4.28.4 Remediation Planning: Architecting a Segmented, Tiered Rollout Sequence to Deploy Hardened GPOs and Script Adjustments Without Halting Operations
- 4.28.5 STIG Implementation Activities: Executing the Transition to Signed LDAP, Disabled NTLM, Kerberos Armoring, and Hardened AD CS Policies Across Active Production Environments
- 4.28.6 Assessment Validation: Re-scanning Hard-Hit System Assets to Confirm the Successful Remediation of Discovered Security Vulnerabilities
- 4.28.7 POA&M Development: Structuring Technical Mitigations and Concrete Remediation Schedules for Outdated Legacy Subsystems That Cannot Support Modern Encrypted Protocols
- 4.28.8 Authorization Impact Analysis: Presenting the Final Hardened Certification and Accreditation / Assessment & Authorization (C&A/A&A) Package to the AO to Move the Infrastructure From an IATO to an ATO
- 4.28.9 Lessons Learned: Why Cross-Functional Technical Simulation, Continuous Change Tracking, and Prioritizing Defenses Over Simple Checklists Dictate Mission Survival

PART I - FOUNDATIONS

Chapter 5. Federal and Military Cybersecurity Assessments Versus Commercial Cybersecurity Assessments

- 5.1 Introduction
 - 5.1.1 Chapter Objectives
 - 5.1.2 Why Assessment Methodologies Matter
 - 5.1.3 Understanding the Federal Assessment Landscape
 - 5.1.4 Assessment Scope and Limitations
- 5.2 The Purpose of Cybersecurity Assessments
 - 5.2.1 Measuring Security Posture
 - 5.2.2 Identifying Risk
 - 5.2.3 Validating Security Controls
 - 5.2.4 Supporting Decision Making
- 5.3 Assessment Philosophies: Federal Versus Commercial
 - 5.3.1 Command and Combatant Mission Assurance Versus Business Risk
 - 5.3.2 National Security Objectives
 - 5.3.3 Regulatory Compliance Objectives
 - 5.3.4 Operational Continuity Considerations
 - 5.3.5 Risk Tolerance Differences
- 5.4 Federal Assessment Frameworks
 - 5.4.1 NIST Assessment Methodologies
 - 5.4.2 RMF Assessment Processes
 - 5.4.3 DoD Assessment Programs
 - 5.4.4 Intelligence Community (IC) Assessment Models
 - 5.4.5 Zero Trust Assessment Requirements
- 5.5 Commercial Assessment Frameworks
 - 5.5.1 PCI DSS Assessments
 - 5.5.2 HIPAA Assessments
 - 5.5.3 SOC Assessments

- 5.5.4 ISO 27001 Assessments
- 5.5.5 Industry-Specific Security Evaluations
- 5.6 Comparing Assessment Scope
 - 5.6.1 Asset Coverage
 - 5.6.2 Identity Infrastructure Scope
 - 5.6.3 Network Scope
 - 5.6.4 Cloud Environment Scope
 - 5.6.5 Third-Party Dependencies
- 5.7 Rules of Engagement (ROE)
 - 5.7.1 Authorization Requirements
 - 5.7.2 Scope Restrictions
 - 5.7.3 Safety Considerations
 - 5.7.4 Operational Impact Limitations
 - 5.7.5 Legal and Regulatory Constraints
- 5.8 Assessment Roles and Stakeholders
 - 5.8.1 Authorizing Officials (AO)
 - 5.8.2 Information Systems Security Officers (ISSOs)
 - 5.8.3 Information Systems Security Managers (ISSMs)
 - 5.8.4 Information Systems Security Engineers (ISSEs)
 - 5.8.5 Security Control Assessors (SCAs)
 - 5.8.6 Penetration Testing Teams
 - 5.8.7 Red Teams
- 5.9 Vulnerability Assessments
 - 5.9.1 Federal Vulnerability Assessment Objectives
 - 5.9.2 Commercial Vulnerability Assessment Objectives
 - 5.9.3 Automated Scanning Approaches
 - 5.9.4 Manual Validation Techniques
 - 5.9.5 Risk Prioritization Methods
- 5.10 Penetration Testing
 - 5.10.1 Purpose and Methodology
 - 5.10.2 Federal Penetration Testing Requirements
 - 5.10.3 Commercial Penetration Testing Objectives
 - 5.10.4 Internal Versus External Testing
 - 5.10.5 Identity-Centric Attack Paths
- 5.11 Red Team Operations
 - 5.11.1 Purpose of Red Teaming
 - 5.11.2 Adversary Emulation
 - 5.11.3 Threat Intelligence Integration
 - 5.11.4 Military Red Team Methodologies
 - 5.11.5 Commercial Red Team Engagements
- 5.12 Active Directory Assessment Methodologies
 - 5.12.1 Active Directory Attack Surface Analysis
 - 5.12.2 Identity Enumeration Techniques
 - 5.12.3 Authentication Security Validation
 - 5.12.4 Privileged Access Assessment
 - 5.12.5 Trust Relationship Analysis
 - 5.12.6 Delegation and Access Control List (ACL) Assessment
 - 5.12.7 Kerberos Security Evaluation
- 5.13 Assessment Artifacts and Deliverables
 - 5.13.1 Security Assessment Reports (SARs)

- 5.13.2 Risk Findings
- 5.13.3 Technical Evidence
- 5.13.4 Executive Briefings
- 5.13.5 Remediation Recommendations
- 5.14 Continuous Monitoring and Reassessment
 - 5.14.1 Continuous Monitoring Programs
 - 5.14.2 Ongoing Vulnerability Assessments
 - 5.14.3 Threat-Based Reassessment
 - 5.14.4 Metrics and Reporting
 - 5.14.5 Assessment Maturity Models
- 5.15 Case Study. Federal Active Directory Security Assessment
 - 5.15.1 Planning Phase
 - 5.15.2 Assessment Execution
 - 5.15.3 Findings Analysis
 - 5.15.4 Risk Determination
 - 5.15.5 Remediation Roadmap
- 5.16 Chapter Summary
 - 5.16.1 Key Concepts Reviewed
 - 5.16.2 Federal Versus Commercial Assessment Differences
 - 5.16.3 Transition to Federal Active Directory Architecture
- ***
- 5.16.4 Why Federal and Military Cybersecurity Assessments Exist
- 5.16.5 Evolution of Federal and Military Cybersecurity Evaluation Programs
- 5.16.6 Command and Combatant Mission Assurance and Cybersecurity Readiness
- 5.16.7 Relationship Between RMF, Continuous Monitoring, and Cybersecurity Assessments
- 5.16.8 Compliance Validation Versus Operational Readiness
- 5.16.9 Why Assessments Are Critical to Active Directory ISSOs
- 5.17 Command and Combatant Cyber Readiness Inspection (CCRI)
 - 5.17.1 Origin and Evolution of CCRI
 - 5.17.2 Purpose and Objectives
 - 5.17.3 CCRI Assessment Methodologies
 - 5.17.4 CCRI Assessment Domains
 - 5.17.5 CCRI Findings and Vulnerability Severity Scoring
 - 5.17.6 Strengths and Limitations
 - 5.17.7 Historical Impact
- 5.18 Command and Combatant Cyber Operational Readiness Assessment (CORA)
 - 5.18.1 Evolution From CCRI to CORA
 - 5.18.2 Purpose and Objectives
 - 5.18.3 Operational Readiness Assessment Methodologies
 - 5.18.3.1 Continuous Assessment Philosophy
 - 5.18.3.2 Key Indicators of Risk (KIORs)
 - 5.18.3.3 MITRE ATT&CK Framework Mapping
 - 5.18.3.4 Boundary Security Evaluation
 - 5.18.3.5 Threat-Informed Risk Scoring
 - 5.18.4 Mission Assurance and Risk-Based Evaluations
 - 5.18.5 CORA Assessment Domains
 - 5.18.5.1 Cyber Maintenance

- 5.18.5.2 Network Boundary Security
- 5.18.5.3 Continuous Monitoring (ConMon)
- 5.18.5.4 Vulnerability Management and Patch Compliance
- 5.18.5.5 Mission Assurance Vulnerability Metrics
- 5.18.6 Operational Resilience and Cyber Readiness
- 5.18.7 CORA Findings and Reporting
- 5.18.8 The Future of Federal and Military Assessments

- 5.19 Identity-Centric Assessment Methodologies
 - 5.19.1 Active Directory Security Assessment (ADSA)
 - 5.19.2 Authentication and Authorization Assessment (AA&A)
 - 5.19.3 Privileged Access Management (PAM) Security Assessments
 - 5.19.4 Public Key Infrastructure (PKI) Security Assessments
 - 5.19.5 Active Directory Certificate Services (AD CS) Security Assessments
 - 5.19.6 Active Directory Federation Services (AD FS) Security Assessments
 - 5.19.7 Microsoft Entra ID and Hybrid Identity Security Assessments
 - 5.19.8 Identity Governance and Administrative Security Assessments
 - 5.19.9 Identity Attack Surface Mapping
 - 5.19.10 Authentication Downgrade Paths
 - 5.19.10.1 Identity Object Enumeration
 - 5.19.10.2 Credential Exposure Analysis
 - 5.19.10.2.1 LSASS
 - 5.19.10.2.2 DPAPI
 - 5.19.10.2.3 Token Abuse
 - 5.19.10.3 Active Directory Object Exposure Analysis
 - 5.19.10.4 Kerberos Attack Surface
 - 5.19.10.4.1 AS-REP
 - 5.19.10.4.2 TGS
 - 5.19.10.4.3 Delegation
 - 5.19.10.4.3.1 Constrained Delegation
 - 5.19.10.4.3.2 Unconstrained Delegation
 - 5.19.10.4.3.3 Resource-Based Constrained Delegation (RBCD)
 - 5.19.10.5 Authentication Path Mapping
 - 5.19.10.6 Identity Trust Boundary Weaknesses
 - 5.19.10.7 Identity Attack Surface Reduction Strategies
 - 5.19.11 Active Directory Attack Path Analysis
 - 5.19.11.1 Graph-Based Attack Path Enumeration
 - 5.19.11.2 Privilege Escalation Chain Discovery
 - 5.19.11.3 Lateral Movement Pathway Analysis
 - 5.19.11.4 Domain Trust Exploitation Paths
 - 5.19.11.5 Tier Model Violations
 - 5.19.11.6 Attack Path Reduction Strategies

- 5.20 Vulnerability and Patch Management – Assessment Readiness Strategy
 - 5.20.1 DoD Vulnerability and Patch Management Programs
 - 5.20.2 Vulnerability Discovery and Identification
 - 5.20.3 Security Baseline Scope and Validation
 - 5.20.4 SRG and STIG Compliance Validation
 - 5.20.5 Configuration Change Board (CCB) Reviews
 - 5.20.6 Risk Prioritization and Remediation

- 5.20.7 Continuous Monitoring Activities
- 5.20.8 Automated STIG Compliance Validation
- 5.20.9 Configuration Drift Detection and Control
- 5.20.10 SCAP Automation and Continuous Compliance
- 5.20.11 STIG-to-CCI-to-eMASS Mapping
- 5.20.12 Policy-as-Code Security Baselines
- 5.20.13 Continuous ATO (cATO) Readiness
- 5.20.14 Security Automation Platforms
- 5.20.15 SteelCloud ConfigOS
- 5.20.16 SCAP Ecosystem
- 5.20.17 Digital Twins
- 5.20.18 ServiceNow
- 5.20.19 Splunk

- 5.21 Assessment Evidence and Artifact Collection
 - 5.21.1 Documentation Requirements
 - 5.21.2 Security Control Evidence
 - 5.21.3 Technical Evidence
 - 5.21.4 Administrative Evidence
 - 5.21.5 Operational Evidence
 - 5.21.6 Physical Security Evidence
 - 5.21.7 Artifact Validation Procedures
 - 5.21.8 Supporting Federal and Military Security Assessment Teams

- 5.22 Common Federal and Military Security Assessment Findings
 - 5.22.1 Authentication and Credential Findings
 - 5.22.2 Active Directory Security Misconfigurations
 - 5.22.3 Privileged Access Weaknesses
 - 5.22.4 PKI and Certificate Management Findings
 - 5.22.5 Logging and Auditing Deficiencies
 - 5.22.6 Vulnerability and Patch Management Findings
 - 5.22.7 Weaknesses in Established and Enforced Policies, Procedures, and Documentation
 - 5.22.7.1 User Non-Adherence to Established and Enforced Policies and Procedures
 - 5.22.8 Operational Readiness Findings (Core Local Area Network (LAN))

- 5.23 Risk Analysis, Remediation, and Corrective/Preventive/Detective Actions
 - 5.23.1 Mission Impact Assessment
 - 5.23.2 Risk Determination and Prioritization
 - 5.23.3 Corrective, Preventive, and Detective Action Plans
 - 5.23.4 Remediation Validation
 - 5.23.5 Risk Acceptance Decisions
 - 5.23.6 Preparing for ATO Re-Certification and Re-Test
 - 5.23.7 Maintaining 24x7x365 Continuous Command and Combatant Readiness
 - 5.23.8 OPSEC and Situational Awareness During Assessments
 - 5.23.9 Automated POA&M Generation
 - 5.23.10 Mapping Findings to MITRE ATT&CK
 - 5.23.11 Threat-Informed Remediation Strategies

5.24 The Assessment Process Through the Eyes of an Active Directory Security Engineer

- 5.24.1 Preparing for a Domain-Wide Security Inspection
- 5.24.2 Supporting Inspection Teams
- 5.24.3 Producing Evidence and Artifacts Upon Request
- 5.24.4 Explaining Findings to CORA Inspectors
- 5.24.5 Quantifying Risk Through POA&Ms
- 5.24.6 Supporting Leadership Risk Decisions
- 5.24.7 Lessons Learned

5.25 Case Study: CORA Security Assessment of a Federal/Military AD Enterprise

- 5.25.1 Assessment Preparation
- 5.25.2 Assessment Execution
- 5.25.3 Discovery of Identity-Related Findings
- 5.25.4 Risk Analysis and Mission Impact
- 5.25.5 Remediation Activities
- 5.25.6 Reassessment and Validation
- 5.25.7 Lessons Learned

PART II – ACTIVE DIRECTORY ARCHITECTURE AND ENTERPRISE IDENTITY INFRASTRUCTURE

Chapter 6. Federal and Military Active Directory Architecture

- 6.1 Introduction
 - 6.1.1 Chapter Objectives
 - 6.1.2 Active Directory as Critical Infrastructure
 - 6.1.3 The Role of Architecture in Identity Security
 - 6.1.4 Federal and Military Design Considerations
- 6.2 Evolution of Active Directory Architecture
 - 6.2.1 Origins of Active Directory
 - 6.2.2 Active Directory in Enterprise Environments
 - 6.2.3 Active Directory in Government Networks
 - 6.2.4 Active Directory and Zero Trust Formation
- 6.3 Active Directory Architectural Principles
 - 6.3.1 Centralized Identity Management
 - 6.3.2 Authentication and Authorization Services
 - 6.3.3 Scalability and Enterprise Growth
 - 6.3.4 High Availability Requirements
 - 6.3.5 Secure-by-Design Principles
- 6.4 Forest Architecture
 - 6.4.1 Understanding Forests
 - 6.4.2 Forest Root Domains
 - 6.4.3 Forest Boundaries
 - 6.4.4 Forest Functional Levels
 - 6.4.5 Forest Design Strategies
- 6.5 Domain Architecture
 - 6.5.1 Understanding Domains
 - 6.5.2 Domain Naming Conventions
 - 6.5.3 Domain Security Boundaries
 - 6.5.4 Single-Domain Models
 - 6.5.5 Multi-Domain Models
- 6.6 Organizational Unit (OU) Design

- 6.6.1 Purpose of Organizational Units
- 6.6.2 Administrative Delegation
- 6.6.3 Security Boundaries Versus Administrative Boundaries
- 6.6.4 OU Design Methodologies
- 6.6.5 Common Organizational Unit (OU) Structures
- 6.7 Site Architecture
 - 6.7.1 Active Directory Sites
 - 6.7.2 Subnets and Site Mapping
 - 6.7.3 Site Links
 - 6.7.4 Replication Topology
 - 6.7.5 Wide Area Network (WAN) Optimization Considerations
- 6.8 Domain Controllers (DCs)
 - 6.8.1 Domain Controller Roles
 - 6.8.2 Read-Only Domain Controllers (RODC)
 - 6.8.3 Global Catalog Servers (GCS)
 - 6.8.4 Domain Controller Placement
 - 6.8.5 Security Considerations
- 6.9 Flexible Single Master Operations (FSMO)
 - 6.9.1 Understanding FSMO Roles
 - 6.9.2 Schema Master
 - 6.9.3 Domain Naming Master
 - 6.9.4 Relative ID (RID) Master
 - 6.9.5 Primary Domain Controller Emulator (PDCe)
 - 6.9.6 Infrastructure Master
 - 6.9.7 FSMO Placement Strategies
- 6.10 Domain Name Service (DNS) and Active Directory Integration
 - 6.10.1 Why DNS Is Critical to Active Directory Domain Services (AD DS)
 - 6.10.2 AD-Integrated DNS Zones
 - 6.10.3 SRV (Service) Records
 - 6.10.4 Name Resolution Security
 - 6.10.5 DNS Hardening Strategies
- 6.11 Enterprise Identity Infrastructure
 - 6.11.1 Identity Stores
 - 6.11.2 Directory Services
 - 6.11.3 Federation Services
 - 6.11.4 Certificate Services
 - 6.11.5 Cloud Identity Integration
- 6.12 Federal Architectural Considerations
 - 6.12.1 Command and Combatant Mission Assurance Requirements
 - 6.12.2 Classified and Unclassified Environments
 - 6.12.3 Cross-Domain Considerations
 - 6.12.4 Continuity of Operations (COOP)
 - 6.12.5 Identity Resilience Strategies
- 6.13 Chapter Summary
 - 6.13.1 Key Concepts Reviewed
 - 6.13.2 Architectural Design Principles
 - 6.13.3 Preparing for Core Components

dfdfd

PART II – ACTIVE DIRECTORY ARCHITECTURE AND ENTERPRISE IDENTITY INFRASTRUCTURE

Chapter 7. Active Directory Core Components and Active Directory Domain Services (AD DS)

- 7.1 Introduction
 - 7.1.1 Chapter Objectives
 - 7.1.2 Understanding Directory Services
 - 7.1.3 Core Components Overview
- 7.2 Active Directory Databases
 - 7.2.1 NTDS.dit Overview
 - 7.2.2 Database Structure
 - 7.2.3 Data Storage Mechanisms
 - 7.2.4 Database Maintenance
 - 7.2.5 Database Security
- 7.3 Active Directory Objects
 - 7.3.1 Object-Oriented Architecture
 - 7.3.2 Distinguished Names (DN)
 - 7.3.3 Relative Distinguished Names
 - 7.3.4 Object Attributes
 - 7.3.5 Object Relationships
- 7.4 User Objects
 - 7.4.1 User Account Fundamentals
 - 7.4.2 User Attributes
 - 7.4.3 User Lifecycle Management
 - 7.4.4 Service Accounts
 - 7.4.5 Managed Service Accounts (MSA)
- 7.5 Group Objects
 - 7.5.1 Security Groups
 - 7.5.2 Distribution Groups
 - 7.5.3 Group Scopes
 - 7.5.4 Nested Groups
 - 7.5.5 Group Management Strategies
- 7.6 Computer Objects
 - 7.6.1 Computer Accounts
 - 7.6.2 Domain Join Process
 - 7.6.3 Information Systems
 - 7.6.4 Servers
 - 7.6.5 Device Management
- 7.7 Organizational Units (OU)
 - 7.7.1 OU Functionality
 - 7.7.2 Delegation Models
 - 7.7.3 Group Policy Object (GPO) Application
 - 7.7.4 Administrative Design
 - 7.7.5 Security Considerations
- 7.8 Active Directory Schema
 - 7.8.1 Schema Fundamentals
 - 7.8.2 Classes and Attributes
 - 7.8.3 Schema Extensions
 - 7.8.4 Schema Security
 - 7.8.5 Schema Management
- 7.9 Replication Services
 - 7.9.1 Replication Fundamentals

- 7.9.2 Multi-Master Replication
- 7.9.3 Replication Topology
- 7.9.4 Replication Conflicts
- 7.9.5 Troubleshooting Replication
- 7.10 Global Catalog Services
- 7.10.1 Purpose of the Global Catalog
- 7.10.2 Universal Group Membership
- 7.10.3 Forest-Wide Searches and Queries
- 7.10.4 Placement Strategies
- 7.10.5 Security Considerations
- 7.11 Active Directory Administrative Tools
- 7.11.1 Active Directory Users and Computers (ADUC)
- 7.11.2 Active Directory Administrative Center
- 7.11.3 ADSI Edit
- 7.11.4 PowerShell Management
- 7.11.5 RSAT Components
- 7.12 Chapter Summary
- 7.12.1 Key Concepts Reviewed
- 7.12.2 Core Services Recap
- 7.12.3 Preparing for Authentication

PART II – ACTIVE DIRECTORY ARCHITECTURE AND ENTERPRISE IDENTITY INFRASTRUCTURE

Chapter 8. Authentication, Authorization, and Access Control

- 8.1 Introduction
- 8.1.1 Chapter Objectives
- 8.1.2 Identity Verification Fundamentals
- 8.1.3 Access Control Concepts
- 8.2 Authentication Fundamentals
- 8.2.1 What Is Authentication?
- 8.2.2 Factors of Authentication
- 8.2.3 Authentication Workflows
- 8.2.4 Identity Proofing
- 8.2.5 Credential Validation
- 8.3 Kerberos Authentication Protocol
- 8.3.1 Kerberos Overview
- 8.3.2 Kerberos Components
- 8.3.3 Ticket Granting Tickets (TGT)
- 8.3.4 Service Tickets (TGS)
- 8.3.5 Kerberos Authentication Flow
- 8.3.6 Kerberos Security Benefits
- 8.4 New Technology Local Area Network (LAN) Manager (NTLM) Authentication
- 8.4.1 NTLM Overview
- 8.4.2 NTLM Authentication Process
- 8.4.3 Legacy System Dependencies
- 8.4.4 Security Limitations
- 8.4.5 NTLM Reduction Strategies
- 8.5 Authorization Fundamentals
- 8.5.1 What Is Authorization?
- 8.5.2 Security Principles
- 8.5.3 Access Tokens

- 8.5.4 Group Membership Evaluation
 - 8.5.5 Effective Permissions
 - 8.6 Access Control Models
 - 8.6.1 Discretionary Access Control (DAC)
 - 8.6.2 Role-Based Access Control (RBAC)
 - 8.6.3 Attribute-Based Access Control (ABAC)
 - 8.6.4 Policy-Based Access Control (PBAC)
 - 8.6.5 Risk-Based Access Control (R-bAC)
 - 8.7 Access Control Lists (ACLs)
 - 8.7.1 ACL Fundamentals
 - 8.7.2 Access Control Entries (ACE)
 - 8.7.3 Inheritance
 - 8.7.4 Effective Permissions Analysis
 - 8.7.5 Common Misconfigurations
 - 8.8 Multifactor Authentication (MFA)
 - 8.8.1 MFA Fundamentals
 - 8.8.2 Common Access Cards (CACs) and Smart Cards
 - 8.8.3 CAC Authentication
 - 8.8.4 Personal Identity Verification (PIV) Authentication
 - 8.8.5 Certificate-Based Authentication
 - 8.9 Single Sign-On (SSO) and Federation
 - 8.9.1 Single Sign-On (SSO) Concepts
 - 8.9.2 Federated Authentication
 - 8.9.3 Identity Providers (IdPs)
 - 8.9.4 Claims-Based Authentication
 - 8.9.5 Trust Relationships
 - 8.10 Authentication Security Challenges
 - 8.10.1 Credential Theft
 - 8.10.2 Password-Based Attacks
 - 8.10.3 Session Hijacking
 - 8.10.4 Pass-the-Hash (PtH)
 - 8.10.5 Pass-the-Ticket (PtT)
 - 8.11 Chapter Summary
 - 8.11.1 Key Concepts Reviewed
 - 8.11.2 Authentication and Authorization Recap
 - 8.11.3 Preparing for Public Key Infrastructure (PKI) and Smart Card Infrastructure
- ***

PART II – ACTIVE DIRECTORY ARCHITECTURE AND ENTERPRISE IDENTITY INFRASTRUCTURE

Chapter 9. Public Key Infrastructure (PKI), CAC, PIV, and Certificate Services

- 9.1 Introduction
 - 9.1.1 Chapter Objectives
 - 9.1.2 Why PKI Matters in Federal Identity
 - 9.1.3 Relationship Between PKI and FICAM
 - 9.1.4 Trust as the Foundation of Digital Identity
- 9.2 Fundamentals of Public Key Infrastructure (PKI)
 - 9.2.1 What Is PKI?
 - 9.2.2 Symmetric Versus Asymmetric Cryptography
 - 9.2.3 Public and Private Keys
 - 9.2.4 Digital Signatures

- 9.2.5 Certificate-Based Trust Models
- 9.3 X.509 Digital Certificates
 - 9.3.1 Certificate Components
 - 9.3.2 Certificate Lifecycles
 - 9.3.3 Certificate Extensions
 - 9.3.4 Certificate Validation
 - 9.3.5 Certificate Revocation and Certificate Revocation Lists (CRL)
- 9.4 Certificate Authorities (CA)
 - 9.4.1 Root Certificate Authorities
 - 9.4.2 Intermediate Certificate Authorities
 - 9.4.3 Issuing Certificate Authorities
 - 9.4.4 Offline Root Architectures
 - 9.4.5 Enterprise Certificate Authority (CA) Design
- 9.5 Active Directory Certificate Services (AD CS)
 - 9.5.1 AD CS Overview
 - 9.5.2 Enterprise CA Deployment
 - 9.5.3 Standalone CA Deployment
 - 9.5.4 Certificate Templates
 - 9.5.5 Web Enrollment Services
- 9.6 Federal Public Key Infrastructure (PKI) Architecture
 - 9.6.1 Federal PKI Overview
 - 9.6.2 Federal Bridge Certificate Authority
 - 9.6.3 Trust Anchors
 - 9.6.4 Cross-Certification Models
 - 9.6.5 Interagency Trust Relationships
- 9.7 Common Access Cards (CACs)
 - 9.7.1 CAC Overview
 - 9.7.2 CAC Components
 - 9.7.3 Authentication Certificates
 - 9.7.4 Digital Signature Certificates
 - 9.7.5 Encryption Certificates
- 9.8 Personal Identity Verification (PIV)
 - 9.8.1 HSPD-12 Requirements
 - 9.8.2 FIPS 201 Standards
 - 9.8.3 PIV Authentication Models
 - 9.8.4 PIV Credential Lifecycle
 - 9.8.5 PIV in Federal Agencies
- 9.9 Smart Card Authentication
 - 9.9.1 Smart Card Authentication Workflows
 - 9.9.2 Kerberos Authentication Protocol and Smart Cards
 - 9.9.3 Certificate Mapping
 - 9.9.4 PIN Verification
 - 9.9.5 Smart Card Enforcement Policies
- 9.10 Certificate-Based Authentication
 - 9.10.1 Passwordless Authentication Concepts
 - 9.10.2 Multifactor Authentication (MFA) Integration
 - 9.10.3 Certificate Logon Workflows
 - 9.10.4 Device Authentication
 - 9.10.5 Mutual Authentication
- 9.11 Public Key Infrastructure (PKI) Security Considerations

- 9.11.1 Private Key Protection
- 9.11.2 Certificate Authority (CA) Compromise Scenarios
- 9.11.3 Certificate Revocation Challenges
- 9.11.4 Trust Chain Attacks
- 9.11.5 Operational Security (OPSEC) Requirements
- 9.12 Chapter Summary
- 9.12.1 Key Concepts Reviewed
- 9.12.2 PKI's Role in Federal Identity
- 9.12.3 Preparing for Domain Federation and Trusts

PART II – ACTIVE DIRECTORY ARCHITECTURE AND ENTERPRISE IDENTITY INFRASTRUCTURE

Chapter 10. Federation, Trust Relationships, and Cross-Domain Identity

- 10.1 Introduction
 - 10.1.1 Chapter Objectives
 - 10.1.2 The Need for Federated Identity
 - 10.1.3 Trust in Modern Identity Systems
- 10.2 Federation Fundamentals
 - 10.2.1 What is Federation?
 - 10.2.2 Identity Providers (IdPs)
 - 10.2.3 Service Providers (SPs)
 - 10.2.4 Claims-Based Identity
 - 10.2.5 Federated Trust Models
- 10.3 Active Directory Federation Services (AD FS)
 - 10.3.1 Active Directory Federation Services (AD FS) Overview
 - 10.3.2 Federation Architecture
 - 10.3.3 Claims Processing
 - 10.3.4 Token Issuance
 - 10.3.5 Authentication Workflows
- 10.4 Federation Protocols
 - 10.4.1 Security Assertion Markup Language (SAML)
 - 10.4.2 OAuth 2.0
 - 10.4.3 OpenID Connect (OIDC)
 - 10.4.4 WS-Federation
 - 10.4.5 Protocol Comparison
- 10.5 Active Directory Trust Relationships
 - 10.5.1 Trust Fundamentals
 - 10.5.2 Parent-Child Trusts
 - 10.5.3 Tree-Root Trusts
 - 10.5.4 Forest Trusts
 - 10.5.5 External Trusts
- 10.6 Cross-Forest Authentication
 - 10.6.1 Authentication Across Active Directory Forests
 - 10.6.2 Security Identifier (SID) Filtering
 - 10.6.3 Selective Authentication
 - 10.6.4 Resource Access Models
 - 10.6.5 Security Considerations
- 10.7 Federal Federation Architecture
 - 10.7.1 Interagency Trust Models
 - 10.7.2 Federal PKI Integration
 - 10.7.3 Shared Service Providers (SSPs)

- 10.7.4 Mission Partner Environments
- 10.7.5 Coalition Identity Challenges
- 10.8 Zero Trust Federation
- 10.8.1 Identity-Centric Access Decisions
- 10.8.2 Conditional Access
- 10.8.3 Continuous Authentication
- 10.8.4 Risk-Adaptive Trust
- 10.8.5 Future Federation Models
- 10.9 Federation Security Risks
- 10.9.1 Token Theft
- 10.9.2 Trust Exploitation
- 10.9.3 Identity Spoofing
- 10.9.4 Federation Misconfigurations
- 10.9.5 Supply Chain Risks
- 10.10 Chapter Summary
- 10.10.1 Key Concepts Reviewed
- 10.10.2 Trust and Federation Recap
- 10.10.3 Preparing for Privileged Access Security

PART II – ACTIVE DIRECTORY ARCHITECTURE AND ENTERPRISE IDENTITY INFRASTRUCTURE

Chapter 11. Administrative Tiering, Privileged Access Management (PAM), and Tier 0 Security

- 11.1 Introduction
- 11.1.1 Chapter Objectives
- 11.1.2 Why Privileged Access Matters
- 11.1.3 The Tier 0 Concept
- 11.2 Understanding Privileged Access
- 11.2.1 Privileged Accounts
- 11.2.2 Administrative Boundaries
- 11.2.3 Elevated Permissions
- 11.2.4 Attack Surface Expansion
- 11.3 Tiered Administration Models
- 11.3.1 Microsoft Tiering Model
- 11.3.2 Tier 0 Assets
- 11.3.3 Tier 1 Assets
- 11.3.4 Tier 2 Assets
- 11.3.5 Administrative Segmentation
- 11.4 Tier 0 Security
- 11.4.1 Defining Tier 0
- 11.4.2 Domain Controllers
- 11.4.3 Identity Infrastructure Components
- 11.4.4 PKI Components
- 11.4.5 Federation Services
- 11.5 Privileged Access Management (PAM)
- 11.5.1 PAM Fundamentals
- 11.5.2 Just-In-Time (JIT) Access
- 11.5.3 Just Enough Administration (JEA)
- 11.5.4 Credential Vaulting
- 11.5.5 Session Monitoring
- 11.6 Privileged Access Workstations (PAWs) and Secured Administrative

Workstations (SAWs)

- 11.6.1 PAW and SAW Fundamentals
- 11.6.2 Administrative Isolation
- 11.6.3 Secure Administration Workflows
- 11.6.4 Operational Requirements